Designandapplycontext-awareaccess controls based on user identity, device posture, location, and application risk.

S .No	NAME	COLLEGE	CONTACT
01	TAMILVANAN I (Team leader)	Sri Krishna Adithya College Of Arts and Sciences	23bsai260tamilvanan@skacas.ac.in
02	SETHUPATHY C (Team Member)	Sri Krishna Adithya College Of Arts and Sciences	23bsai253sethupathy@skacas.ac.in
03	YOKESH J (Team Member)	Sri Krishna Adithya College Of Arts and Sciences	23bsai265yokeshj@skacas.ac.in
04	ASHWIN S (Team Member)	Sri Krishna Adithya College Of Arts and Sciences	23bsai212ashwins@skacas.ac.in

INTRODUCTION:

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders. In response to this growing challenge, we present a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks.

Thetraditionalnetworkperimeterhasallbut dissolved inthemoderndigitallandscape. Withthemass adoptionofcloudservices,remotework,andpersonalmobiledevices(BYOD),corporatereso urcesare nolongerconfinedtoasingleofficebuilding.Thisshifthasrenderedtheconventional"castle-and-moat" security model—where anyone inside the network is trusted by default—obsolete and dangerously insufficient. Modern organizations now face the complex challenge of securing access to sensitive data from a diverse and ever-changing array of locations, devices, and user environments. To address this, security strategies must evolve from static, location-centric models to dynamic, identity-centric frameworks that assess the risk of every access request in real-time.

Thisprojectfocusesonthedesignandimplementationofacontext-awareaccesscontrolsystemtosolve this exact challenge. By moving beyond simple username and password verification, this system will evaluate a rich set of contextual signals before granting access to applications and data. These signals include the user's identity and role, the security posture of their device (e.g., is it patched, encrypted, and managed?), their geographic location, and the inherent risk level of the application they are attempting to use. By analyzing these factors in unison, the system can make a granular, real-time decision:grantfullaccess,restrictaccesstocertainfeatures,requirestep-upauthentication(likemulti- factor authentication), or block the request entirely.

Ultimately, this project aims to build a security architecture that is both robust and frictionless. For example, a trusted employee accessing a low-risk application from a secured corporate laptop on the office network might have a seamless login experience. Conversely, that same employee attempting to access a critical financial system from an unpatched personal device in a foreign country would be met with additional security challenges or be completely blocked. This intelligent, adaptive approach not only significantly reduces the attack surface and protects against compromised credentials but also enables a secure and productive work environment for a modern, mobile workforce.

ABSTRACT:

The increasing adoption of cloud services, mobile computing, and hybrid work models has fundamentally broken the traditional network perimeter, rendering legacy access control models ineffective. Organizations now struggle to protect sensitive data from a growing attack surface, where threatscanoriginatefromcompromisedendpoints,unsafelocations,ormaliciousinsiders.Static,binary decisions(allowordeny)arenolongersufficienttomitigatethesophisticated riskspresentinmodern distributed environments. There is a critical need for a dynamic

security framework that can evaluate the full context of every access request in real-time.

Thisprojectpresentsthedesignandapplicationofacontext-awareaccesscontrolsystembasedonuser identity, device posture, geolocation, and application risk. The objective is to develop a policy engine that ingests multiple contextual signals to calculate a real-time risk score for each access attempt. The methodologyinvolvesdefininggranularpoliciesthatmapspecificcontextcombinations(e.g., "managed device" + "corporate network" + "low-risk app") to corresponding access decisions, such as granting full access, enforcing step-up authentication (MFA), limiting session functionality, or denying access entirely.

Theexpectedoutcomeisanadaptivesecuritymodelthatsignificantlyreducestheorganizationalattack surface and mitigates the risk of credential compromise.

By ensuring that access decisions are dynamically aligned with the perceived threat level of each request, the system enhances security without introducing unnecessary friction for low-risk, trusted users. This approach provides a robust framework for enabling secure and productive access to resources in an increasingly perimeter-less and dynamic digital world.

UseCase Scenarios

Scenario1:FinanceDepartmentAccesstoERPSystem

AsenioraccountantinthefinancedepartmentneedstoaccessthecorporateEnterpriseResourcePlanning(ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication(MFA).ZPAevaluatestheuser'sidentity,groupmembership(Finance_ERP_Users),deviceposture (antivirusactive,diskencryptionenabled),andconnectioncontext.Thepolicyenginedeterminesthat theuseris authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- Userauthenticatedandauthorizedbasedonidentityandgroupmembership
- Directmicro-tunnelestablishedspecificallytotheERPapplication
- Allotherinternalapplicationsandnetworksegmentsremaininvisibleandinaccessible

Scenario2:ContractorAccesstoSpecificProjectRepository

An external software consultant is hired for a three-month project and requires access only to a specific Git repositoryhostedonaninternalserver.Thecontractoris onboardedas aguestuserintheidentityproviderand assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identityandchecks the device for basic securitycompliance (OSpatch level, firewallenabled). ZPA enforcesapolicythatgrantsaccessexclusivelytotheGitrepositoryapplication(port22/SSHorport443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

- Time-boundandrole-specificaccessenforced
- Contractorrestrictedtoasingleapplication(Gitrepository)
- Lateralmovementtoadjacentsystemscompletelyblocked

Scenario3:ExecutiveAccesstoSensitiveFinancialDocuments

AcompanyVPneeds toaccess afoldercontainingconfidentialM&Adocumentsstoredinacorporate SharePoint site.Theuserconnectsfromahotelbusinesscenterwhiletravelinginternationally,usingtheircompany-managedtablet.UponlaunchingtheZPAClientConnector,theyauthenticateviaAzureActiveDirectorywithMFA. ZPAevaluatestheuser'sidentity,executivegroupmembership,anddeviceposture(whichiscompliant). However,thegeolocation(unusualforeigncountry)andtheapplicationrisk(highlysensitivedocumentrepository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforcesadditional restrictions: download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login. Output:

- UserauthenticatedwithMFAanddevicecompliant,butflaggedforunusuallocation
- Read-onlyaccessgrantedwithdownload/printrestrictionsenforced
- Securityteamalertedtopotentialcredentialmisuseorespionageattempt

Scenario4:RemoteSupportTechnicianAccesstoInternalTools

AnITsupporttechnicianneeds toaccess thecorporateServiceNowinstanceandaremotedesktoptooltoassist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff). Because the user, device, and location all meet the 信任 baseline, the policy engine grants direct micro-tunnel access to both ServiceNow and the specific remote desktop jump host used for employee support. The technician can perform their duties efficiently, but still has no access to finance systems, HR databases, or source code repositories.

Output:

- Userauthenticatedandfullyauthorizedbasedontrustedcontext
- Directmicro-tunnelsestablishedtoServiceNowandtheremotedesktopjumphost
- Least-privilegeaccessmaintained;unrelatedinternalsystemsremaininvisible

Scenario5:High-RiskApplicationAccessfromaLow-TrustLocation

A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership(Marketing_Salesforce_Users),deviceposture(managedandcompliant),butflagsthepublicWi-Fi network as a high-riskconnection.The policy engine determines that whilethe user and device are trusted, the network environment introduces unacceptable risk for direct access to a customer-facing CRM containing sensitive lead data. Instead of blocking access entirely, the user is routed through a secure ZPA browser isolation service, rendering the Salesforce session in a disposable container that prevents any data from persisting on the device or being exposed to the public network.

Output:

- Userauthenticatedanddevicecompliant,butnetworklocationdeemedhigh-risk
- AccessgrantedviabrowserisolationtopreventdataleakageonpublicWi-Fi
- Sessionisrenderedinasecurecontainerwithcopy/pasteanddownloadcontrolsenforced

Stage–1

Title:

Designandapplycontext-awareaccesscontrolsbasedonuseridentity,deviceposture, location, and application risk.

Overview:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principleof"nevertrust,alwaysverify."Bymovingbeyondlocation-

basedaccess,weaimtoestablisha security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establishdirect,one-to-oneconnectionsbetweenauthorizedusersandspecificapplications,completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, renderingthe applicationsinvisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application accessfromnetworkaccess,wewilleliminatetheriskoflateralmovementacrossthenetwork, asusers have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

ListofVulnerability:

S.No.	VulnerabilityName	CWENo.
1.	Cross-sitescripting(stored)	79
2.	BrokenAccessControl	285
3.	SQL Injection	89
4.	BrokenAuthentication	285
5.	InsecureDirectObjectReference	639

6.	SecurityMisconfiguration	732
7.	Cross-SiteRequestForgery	352
8.	CleartextTransmissionof SensitiveInformation	319
9.	ClickJacking	1021
10.	webserverallowspasswordauto-completion	310
11.	Cross-sitescripting(DOM-basedXSS)	79
12.	JQuery1.2<3.5.0MultipleXSS	79
13.	InformationExposure(WebServerHTTPHeader Internal IP Disclosure)	200
14.	InformationExposure(SSL(MultipleIssues))	200
15.	InformationExposure(HTTP(MultipleIssues))	200
16.	OSIdentificationFailed	200

Report:

1. Vulnerabilityname:Crosssitescripting(stored) CWE: 79

OWASPcategory:A03:2021-Injections

Description: It occurs when a malicious script is injected directly into a vulnerable web application.
ReflectedXSSinvolvesthereflectionofamaliciousscriptofawebapplication,ontoauser'sbrowser.

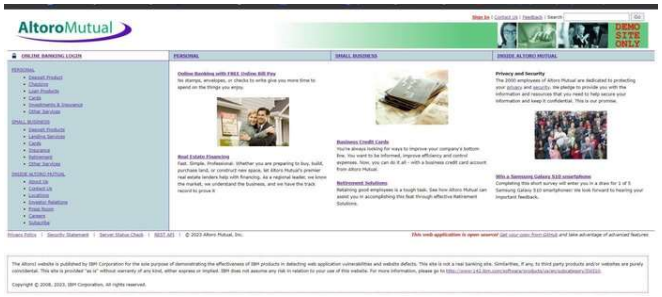
Business Impact: The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequentlyread backinto the applicationandincludedin dynamic content. From anattacker's perspective, the optimal place to inject malicious content is in an area that is displayed to either many users or particularly interesting users. Interesting users typically have elevatedprivilegesintheapplicationorinteractwithsensitivedatathatis valuabletotheattacker.Ifoneof theseusersexecutesmaliciouscontent,theattackermaybeabletoperformprivilegedoperationsonbehalf of the user or gain access to sensitive data belonging to the user.

Vulnerabilitypath:http://testfire.net/

Vulnerability parameter:
http://testfire.net/search.jsp?query=%27%3E%3Cscript%3Ealert%28%27hacked%27%29%3C%2Fscript%3E

StepstoReproduce:

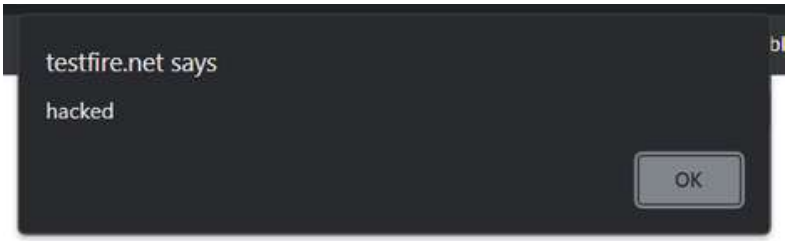
- AccesstheURL



- Inthesearchboxwewillinputsomecodetoperformthevulnerability.

- TheScriptwewillbeinputtingis'><script>alert('hacked')</script>

- Thisdisplaysaharmlesspopupalertboxwiththetextsaying'hacked'



Recommendation:

- Wheninteractingwithdatabases,useparameterizedstatementsorpreparedstatementstoavoid SQL injection, which can be a vector for XSS.
- Sanitizeandvalidatealluserinputsandensurethatanydatadisplayedonthewebpageis properly encoded. Use output encoding libraries or functions to prevent script injection.

1. Vulnerabilityname:Brokenaccesscontrol CWE: 285

Description:Whenaccesscontrolchecksarenotappliedconsistently-ornotatall-usersareabletoaccess data or perform actions that they should not be allowed to perform. This can lead to a wide range of problems, including information exposures, denial of service, and arbitrary code execution.

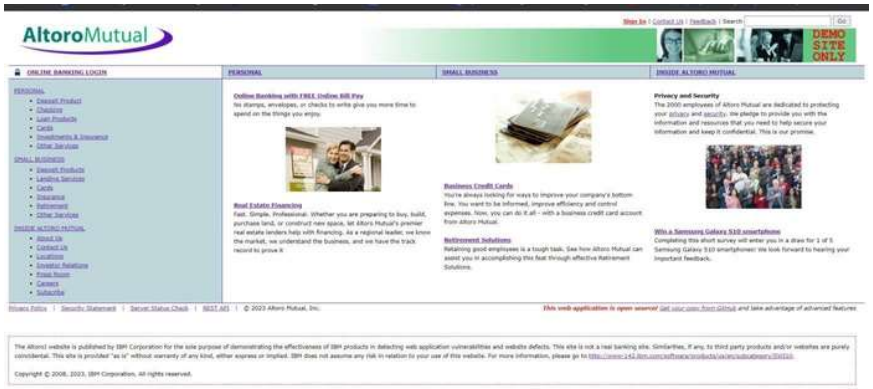
Business Impact: wide-ranging business impact, including financial losses, reputationdamage, legal consequences,operationaldisruption,andlossofcustomertrust.Addressingthisvulnerabilityiscrucialto protect the organization and its stakeholders from these potential negative effects.

Vulnerabilitypath:http://testfire.net/

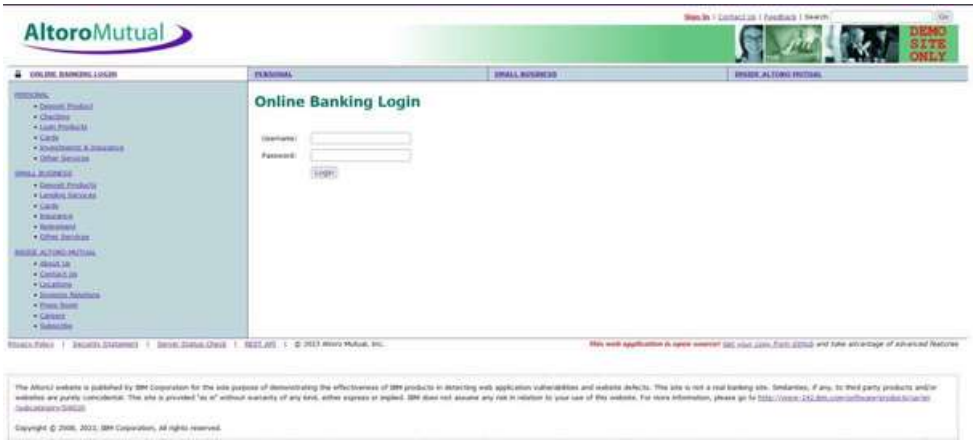
Vulnerabilityparameter:http://testfire.net/login.jsp

StepstoReproduce:

- AccesstheURL



- Nowwewilltrytosignintothiswebsitewithadminprivileges



- Also,wewillbeusingburpsuitetogetrequestsfromthewebsiteandknowadditionalinformation.

Weuse‘admin’fortheusernameandpassword.

- Thisrequesthasbeenreceivedintheburpsuitewiththeusernameandpasswordaswellinclear text.

- nowweclickonforwardrequestintheburpsuiteandthenwewillberedirectedtotheadminuser details.

- Wecanevenedittheotherusersdataanddeletetheirlogindetailsaswell.

Recommendations:

- Ensure that the application has a robust authentication and authorization mechanism in place.Usersshouldbeauthenticatedbeforeanysensitiveactionsareperformed,andauthorizatio

nchecks should be conducted to verify that users have the necessary permissions for the requested operation.

- Ensurethatsessionmanagementissecure.UsestrongsessionIDs,enforcesessiontimeouts,and regenerate session tokens after login. Implement session fixation protection to prevent session hijacking.

1. Vulnerabilityname:SQLinjection CWE: 89

Description:TheproductconstructsallorpartofanSQLcommandusingexternally-influencedinputfrom an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component.

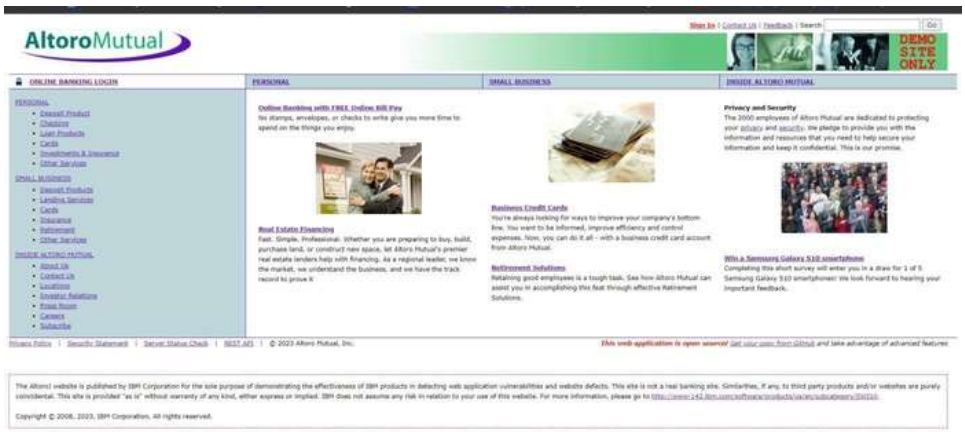
BusinessImpact:Insummary,itiscrucialtounderscorethatCWE-89,knownasSQLInjection,canexerta profound and diverse business impact. This encompasses critical facets such as data breaches, financial setbacks, harm to reputation, legal ramifications, and operational turmoil. Hence, the imperative of preventing and remedying SQL injection vulnerabilities cannot be overstated, as it is indispensable for fortifying the security and continuity of an organization's applications and data.

Vulnerabilitypath:http://testfire.net/

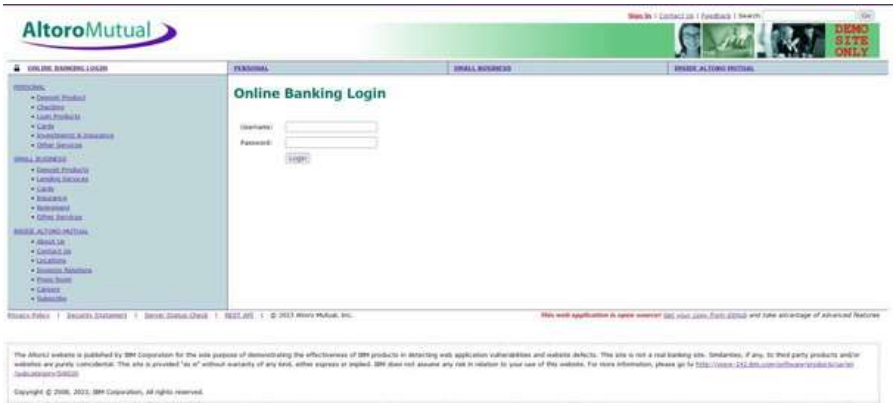
Vulnerabilityparameter:http://testfire.net/login.jsp

StepstoReproduce:

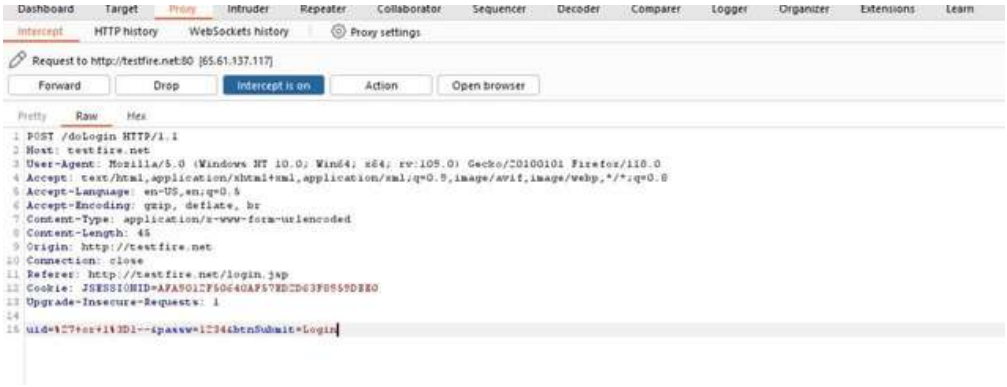
- AccesstheURL



- NowwewilltrytosignintothiswebsitewithadminprivilegesbutusingSQLinjection



- Also,wewillbeusingburpsuitetogetrequestsfromthewebsiteandknowadditionalinformation.



- Clickforwardrequestmultipletimestoproceedtotheloginpage.

- Withthiswecanknowthatsqlinjectionworkedandwegottheadminprivileges.

Recommendations:

- Ifparameterizedstatementsarenotfeasible,useproperinputvalidationandescapingmechanisms to sanitize user inputs before they are used in SQL queries. This helps prevent malicious code injection.
- Utilizestoredproceduresfordatabaseoperations.ThiscanhelpseparateSQLcodefromapplication code and reduce the risk of SQL injection.
- Implementstrictinputvalidationforalluserinputs,ensuringthatdataadherestotheexpected format and structure.

1. Vulnerabilityname:Brokenauthentication CWE: 285

Description:Thesystem'sauthorizationfunctionalitydoesnotpreventoneuserfromgainingaccessto another user's data or record by modifying the key value identifying the data.

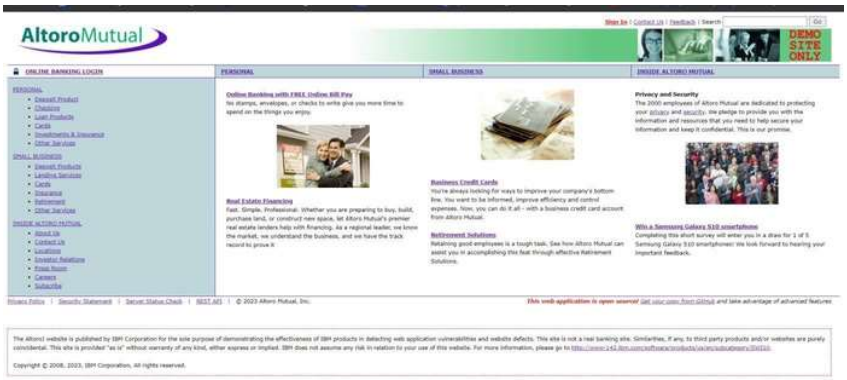
Business Impact:Toeffectivelymitigatethebusiness impactofCWE-285,itisimperativethatorganizations place a strong emphasis on bolstering their authentication and session management practices. This should encompasstheadoptionofmulti-factorauthentication,thesecurestorageofcredentials,meticuloussession handling, and a commitment to conducting routine security assessments and testing. The rectification of these vulnerabilities stands as a critical imperative,safeguarding sensitive data, user identities, andthe organization's overarching security stature and reputation.

Vulnerabilitypath:http://testfire.net/

Vulnerabilityparameter:http://testfire.net/login.jsp

StepstoReproduce:

- AccesstheURL



- Nowwewilltrytologinusingsomedifferentapproach.

- Asweknowwhichusersarepresentinthedatabaseofthiswebsitebyusingtheadminprivilege s. We can directly access a particular user by simply knowing their username; we will add some characters after his user name as a sql injection to simply bypass the password.

- Thisleadsustothedetailsofthisperson’saccount.

Recommendations:

- Implementstrongauthenticationmechanisms,suchasmulti-factorauthentication(MFA)ortwo-factor authentication (2FA), to ensure that only authorized users can access the system.
- Implementproperauthorizationcontrols toensurethat usershave the necessarypermissionsto accessspecificfunctionsordata.Userole-basedaccesscontrol(RBAC)tomanageuserprivileges effectively.
- Deployintrusiondetectionandpreventionsystems(IDS/IPS)tomonitorandblocksuspicious activities related to authentication and authorization.

1. VulnerabilityName:InsecureDirectobjectReference CWE: 639

OWASPCategory: A01:BrokenAccessControl

Description:

Insecure Direct Object Reference (IDOR) is a vulnerability that arises when attackers can access or modify objects bymanipulatingidentifiers usedinawebapplication'sURLs orparameters. Itoccursdue to missing access control checks, which fail to verify whether a user should be allowed to access specific data.

BusinessImpact:

To effectively mitigate the business impact of CWE-639, organizations must make it a top priority to fortify their access control and authorization mechanisms. This entails the implementation of robust security measures, the regular conduct of comprehensive security assessments, and the deployment of intrusion detectionsystems to promptlyidentifyandcounterunauthorizedaccess attempts. Thesemeasures standas absolutelycriticalinthedefenseofsensitivedata,theoverallsecurityofsystems,andthepreservationo fthe organization's esteemed reputation.

VulnerabilityPath:http://testfire.net

VulnerabilityParameter:http://testfire.net/bank/transfer.jsp

StepstoReproduce:

- Gotothe domain.
- Signintothesite.

- Open“TransferMoney”ontheleftsideandfillinthedetails.Ontheinterceptandclicktransfer

- Openburpandnoticethechange.

```
Pretty   Raw   Hex
1  POST /bank/doTransfer HTTP/1.1
2  Host: testfire.net
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/119.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 70
9  Origin: http://testfire.net
10 Connection: close
11 Referer: http://testfire.net/bank/transfer.jsp
12 Cookie: JSESSIONID=17BCE438BBB750A14D265616C76238B0; AltoroAccounts=
   "ODAwMDAwfk0VcnBvcmF0ZX4xLjYzNTczNTM1NjM10Dc0NSUy0Nv4MDAwMDF+Q2hlY2tpbmd+LTNuMjM1NzM1MzU2MzU4NzQ0RTI5fA==" 
13 Upgrade-Insecure-Requests: 1
14
15 fromAccount=800000&toAccount=800001&transferAmount=100&transfer=Transfer+Money
```

- Inthe15thlinechangetheamountfrom100to1000andclickforward

```
fromAccount=800000&toAccount=800001&transferAmount=100&transfer=Transfer+Money

fromAccount=800000&toAccount=800001&transferAmount=1000&transfer=Transfer+Money
```

```
Pretty   Raw   Hex
1  GET /v1/tiles HTTP/1.1
2  Host: contile.services.mozilla.com
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/119.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Te: trailers
8  Connection: close
9
10
```

- Lookatthesite,wecannoticethemsgthatshowsthetransferof1000.

- OfftheInterceptandopen“ViewRecentTransactions”.

Transaction ID	Transaction Time	Account ID	Action	Amount
9016	2023-10-16 06:28	800001	Deposit	$1000.00
9015	2023-10-16 06:28	800000	Withdrawal	-$1000.00
8920	2023-10-16 04:46	800001	Deposit	$23345.00
8919	2023-10-16 04:46	800000	Withdrawal	-$23345.00
8916	2023-10-16 04:44	800001	Deposit	$23345.00
8915	2023-10-16 04:44	800000	Withdrawal	-$23345.00
8894	2023-10-16 04:40	800001	Deposit	$23345.00
8893	2023-10-16 04:40	800000	Withdrawal	-$23345.00
8892	2023-10-16 04:40	800001	Deposit	$23345.00
8891	2023-10-16 04:40	800000	Withdrawal	-$23345.00
7565	2023-10-16 04:17	800000	Withdrawal	-$10.00
7228	2023-10-16 04:14	800000	Deposit	$1000.00
6802	2023-10-16 04:09	800001	Deposit	$1000000000000000.00
6801	2023-10-16 04:09	800000	Withdrawal	-$1000000000000000.00
5388	2023-10-16 03:58	800000	Deposit	$1000000000000.00
4628	2023-10-16 03:36	800001	Deposit	$20190.00
4627	2023-10-16 03:36	800000	Withdrawal	-$20190.00
4626	2023-10-16 03:35	800001	Deposit	$20190.00
4625	2023-10-16 03:35	800000	Withdrawal	-$20190.00
4624	2023-10-16 03:35	800001	Deposit	$600.00
4623	2023-10-16 03:35	800000	Withdrawal	-$600.00
4616	2023-10-16 03:10	800000	Deposit	$87446.00
4615	2023-10-16 03:10	800001	Withdrawal	-$87446.00

Recommendation:

- UtilizeparameterizedqueriesorpreparedstatementswheninteractingwithdatabasesThis prevents user-controlled input from being executed as SQL code.
- ImplementaContentSecurityPolicytomitigatetheriskofcross-sitescripting(XSS)attacks, which can be used to execute unauthorized queries.
- Implementaccountlockoutmechanismsthattemporarilysuspendaccountsafteraspecified number of unauthorized access attempts to prevent brute force attacks.

1. Vulnerabilityname:SecurityMisconfiguration CWE:732

Description: The product specifies permissions for a security-critical resource in a way that allows that resource to be read or modified by unintended actors.

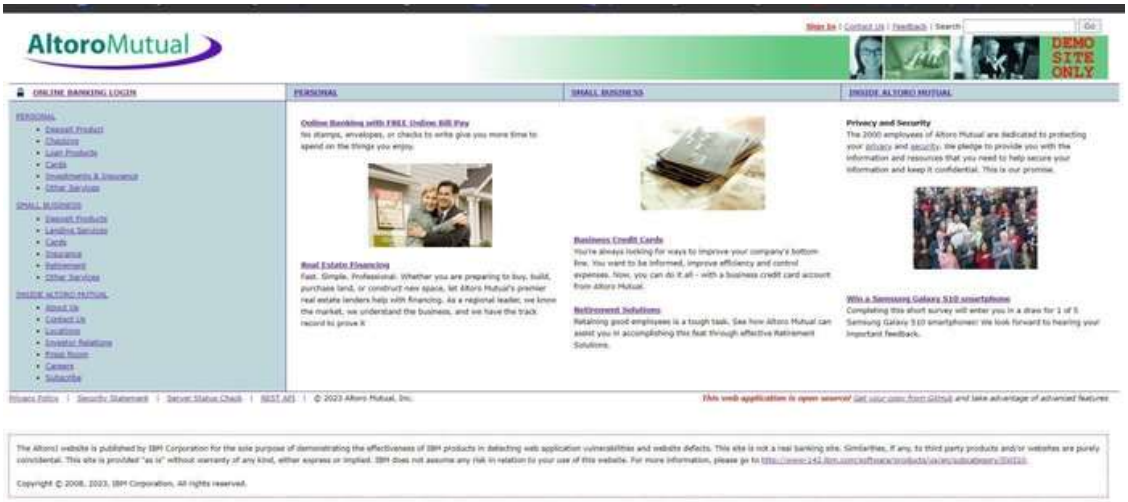
Business Impact: To effectively lessen the business consequences stemming from CWE-732, organizations must place a strong emphasis on bolstering their configuration management practices. This involves the establishmentofsecuredefaultsettings,theroutineconductofcomprehensivesecurityevaluations,andthe deployment of intrusion detection systems to promptly detect and address misconfigurations and vulnerabilities. These actions are of paramount importanceinsafeguarding sensitive data, fortifying system security, and preserving the organization's esteemed reputation.

Vulnerabilitypath:http://testfire.net/

Vulnerabilityparameter:http://testfire.net/login.jsp

StepstoReproduce:

- AccesstheURL



- Wewillbeusingtheuniscantoolwhichisavailableinthekali.

```
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
[sudo] password for kali:
######################################
# Uniscan project                    #
# http://uniscan.sourceforge.net/    #
######################################
V. 6.3

OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r
```

- Wewillusethistooltoscanforhiddendirectories thatcanbeaccessduetopoorsecuritymeasures taken in this website.

```
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -u http://testfire.net/ -qweds
[sudo] password for kali:
#####################################
# Uniscan project                   #
# http://uniscan.sourceforge.net/   #
#####################################
V. 6.3


Scan date: 17-10-2023 7:18:22
=============================================================================
| Domain: http://testfire.net/
| Server: Apache-Coyote/1.1
| IP: 65.61.137.117
=============================================================================
|
| Directory check:
| [+] CODE: 200 URL: http://testfire.net/admin/fckeditor/admins/
| [+] CODE: 200 URL: http://testfire.net/admin/
| [+] CODE: 200 URL: http://testfire.net/admin/scripts/fckeditor/
| [+] CODE: 200 URL: http://testfire.net/admin/FCKeditor/
| [+] CODE: 200 URL: http://testfire.net/aux/
| [+] CODE: 200 URL: http://testfire.net/bank/
=============================================================================
|
```

- Wefounddirectoriesthatcanbeaccessedeasily.Alsoallthefiles thatarepresentinthewebsitehas also been found.

```
|
| File check:
| [+] CODE: 200 URL: http://testfire.net/admin/account.asp
| [+] CODE: 200 URL: http://testfire.net/admin/account.html
| [+] CODE: 200 URL: http://testfire.net/admin/admin.php
| [+] CODE: 200 URL: http://testfire.net/admin/admin_phpinfo.php4
| [+] CODE: 200 URL: http://testfire.net/admin/account.php
| [+] CODE: 200 URL: http://testfire.net/admin/admin.shtml
| [+] CODE: 200 URL: http://testfire.net/admin/aindex.htm
| [+] CODE: 200 URL: http://testfire.net/admin/auth.php
| [+] CODE: 200 URL: http://testfire.net/admin/cfg/configscreen.inc.php+
| [+] CODE: 200 URL: http://testfire.net/admin/cfg/configsite.inc.php+
| [+] CODE: 200 URL: http://testfire.net/admin/cfg/configsql.inc.php+
| [+] CODE: 200 URL: http://testfire.net/admin/cfg/configtache.inc.php+
| [+] CODE: 200 URL: http://testfire.net/admin/cms/htmltags.php
| [+] CODE: 200 URL: http://testfire.net/admin/config.php
| [+] CODE: 200 URL: http://testfire.net/admin/contextAdmin/contextAdmin.html
| [+] CODE: 200 URL: http://testfire.net/admin/controlpanel.asp
| [+] CODE: 200 URL: http://testfire.net/admin/controlpanel.php
| [+] CODE: 200 URL: http://testfire.net/admin/controlpanel.html
| [+] CODE: 200 URL: http://testfire.net/admin/cplogfile.log
| [+] CODE: 200 URL: http://testfire.net/admin/cp.php
| [+] CODE: 200 URL: http://testfire.net/admin/cp.html
| [+] CODE: 200 URL: http://testfire.net/admin/database/wwForum.mdb
| [+] CODE: 200 URL: http://testfire.net/admin/credit_card_info.php
| [+] CODE: 200 URL: http://testfire.net/admin/datasource.asp
| [+] CODE: 200 URL: http://testfire.net/admin/db.php
| [+] CODE: 200 URL: http://testfire.net/admin/home.asp
| [+] CODE: 200 URL: http://testfire.net/admin/home.php
| [+] CODE: 200 URL: http://testfire.net/admin/index.asp
| [+] CODE: 200 URL: http://testfire.net/admin/index.html
| [+] CODE: 200 URL: http://testfire.net/admin/index.php
| [+] CODE: 200 URL: http://testfire.net/admin/phpinfo.php
| [+] CODE: 200 URL: http://testfire.net/admin/settings.inc.php+
| [+] CODE: 200 URL: http://testfire.net/admin/system_footer.php
| [+] CODE: 200 URL: http://testfire.net/admin/upload.php
| [+] CODE: 200 URL: http://testfire.net/admin/templates/header.php
| [+] CODE: 200 URL: http://testfire.net/admin/wg_user-info.ml
| [+] CODE: 200 URL: http://testfire.net/admin/script.php
| [+] CODE: 200 URL: http://testfire.net/login.jsp
=============================================================================
|
```

- Letusgothroughonewebpagetoseethevulnerability

- Herewecanseethesensitivedataofjobapplicationswhichcanhelpanattacker.

Recommendations:

- Implementachangemanagementprocesstodocumentandreviewallchangestosystem configurations. This helps prevent unauthorized or unintended alterations.
- Followsecurityguidelinesprovidedbysoftwareandhardwarevendorstoensuresecure configurations.
- Regularlyperformcompliancechecksagainstindustrystandardsandregulationstoensurethat configurations remain in compliance with security requirements.

1. VulnerabilityName:Cross-SiteRequestForgery CWS: 352

OWASPCategory:A08:Cross-SiteRequestForgery Description:

Cross-Site Request Forgery (CSRF) is an attack that forces an end user to execute unwanted actions on a web application in which they're currently authenticated. With a little help of social engineering (such as sendingalinkviaemailorchat),anattackermaytricktheusersofawebapplicationintoexecutingactions of the attacker's choosing. If the victim is a normal user, a successful CSRF attack can force the user to perform state changing requests like transferring funds, changing their emailaddress, and so forth. If the victim is an administrative account, CSRF can compromise the entire web application.

BusinessImpact:

To effectively reduce the business repercussions of CWE-352, organizations must prioritize secure coding practices, including the incorporation of anti-CSRF tokens, while also conducting routine security assessments andtestingto detectandrectifyCSRFvulnerabilities. Furthermore, educatingusers onsecure browsingpracticesispivotalinpreventingCSRFattacks.Theseactionsareofparamountimportancein the protection of data and in upholding the trust of customers and partners.

VulnerabilityPath:http://testfire.net/

VulnerabilityParameter:http://testfire.net/bank/transfer.jsp

StepstoReproduce:

- Openhttps://testfire.net/.

- Logintoitusingdefaultcredentials,andyouwillfindtwoaccounts.

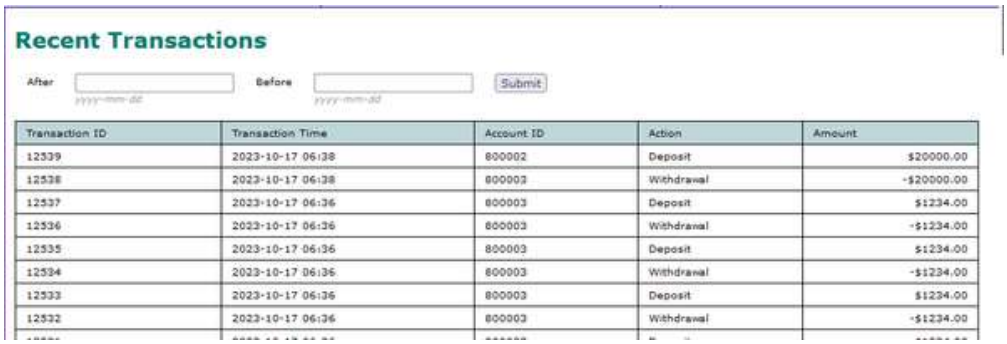
- CapturetherequestinanyInterceptingproxy(BurpSuite,CharlesProxyetc.)whiletransferringthe amount from one account to another as shown in the below picture.

- GenerateCSRFPOCusingBurpSuiteEngagementtools(bymodifyingtheaccountnumbers accordingly)

- Asthevictimisalreadylogged-intothesiteanattackercansendthecraftedmaliciousform/URLto the user to his email/text/by any other means and trick the victim using his social engineering skills/techniques like below.

- Userthinks,hecoulduseafree$100giftcard!Whatcouldgowrong?Youopentheemailandclick the link/open the attachment.

- Oncetheuseropenstheformatransactionisautomaticallyperformedfromhisaccountwithouthis knowledge as the user is already logged in.



Recent Transactions

After yyyy-mm-dd Before yyyy-mm-dd Submit

Transaction ID	Transaction Time	Account ID	Action	Amount
12539	2023-10-17 06:38	800002	Deposit	$20000.00
12538	2023-10-17 06:38	800003	Withdrawal	-$20000.00
12537	2023-10-17 06:36	800003	Deposit	$1234.00
12536	2023-10-17 06:36	800003	Withdrawal	-$1234.00
12535	2023-10-17 06:36	800003	Deposit	$1234.00
12534	2023-10-17 06:36	800003	Withdrawal	-$1234.00
12533	2023-10-17 06:36	800003	Deposit	$1234.00
12532	2023-10-17 06:36	800003	Withdrawal	-$1234.00

Recommendations:

- ImplementSynchronizerToken Patterns toincludeunique,randomlygenerated tokensin each HTTPrequestandvalidatethesetokensontheserversidetoverifytheauthenticityoftherequest.
- Utilizethe SameSite attribute in cookies to restrict theirusage tosame-site requests only, preventingthemfrombeingsentalongwithcross-siterequestsandeffectivelymitigatingCSRF attacks.

- Utilizeframework-specificprotectionsandsecurityfeaturestopreventCSRFattacks.Manymodern web frameworks have built-in mechanisms and libraries for handling CSRF vulnerabilities effectively.
- ImplementaContentSecurityPolicytorestrictthesources from whichvarious typesofcontentcan be loaded. Byspecifying the trustedsources ofcontent, you canminimize theriskof maliciouscode execution and reduce the likelihood of successful CSRF attacks.

1. Vulnerabilityname:CleartextTransmissionofSensitiveInformation CWE: 319

Description: The product transmits sensitive or security-critical data in cleartext in a communication channel that can be sniffed by unauthorized actors. Many communication channels can be "sniffed" (monitored) by adversaries during data transmission. For example, in networking, packets can traverse many intermediary nodes from the source to the destination, whether across the internet, an internal network,thecloud,etc.Someactorsmighthaveprivilegedaccesstoanetworkinterfaceoranylinkalong thechannel,suchas arouter,buttheymightnotbeauthorizedtocollecttheunderlying data.As aresult, network traffic could be sniffed by adversaries, spilling security-critical data.

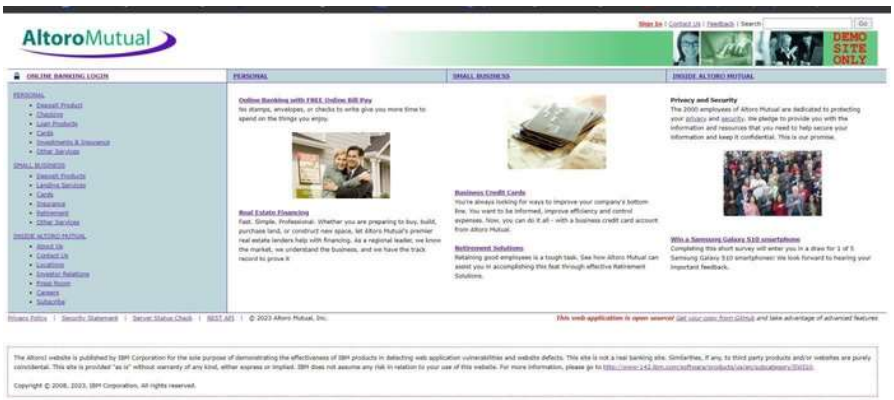
Business Impact: To effectively reduce the businessconsequences associated with CWE-319,organizations must prioritize the adoption of secure data transmission practices. This includes the utilization of encryption androbust, secure protocols.Theroutine conduct ofsecurity assessments and testing is pivotal in pinpointing and remedying vulnerabilities linked to data transmission. Furthermore, the education of users onsecure datahandling practices plays a vitalroleinproactivelypreventing data exposureincidents. Theseactionsareofparamountimportanceintheprotectionofsensitivedataandinpreservingthetrust of both customers and partners.

Vulnerabilitypath:http://testfire.net/

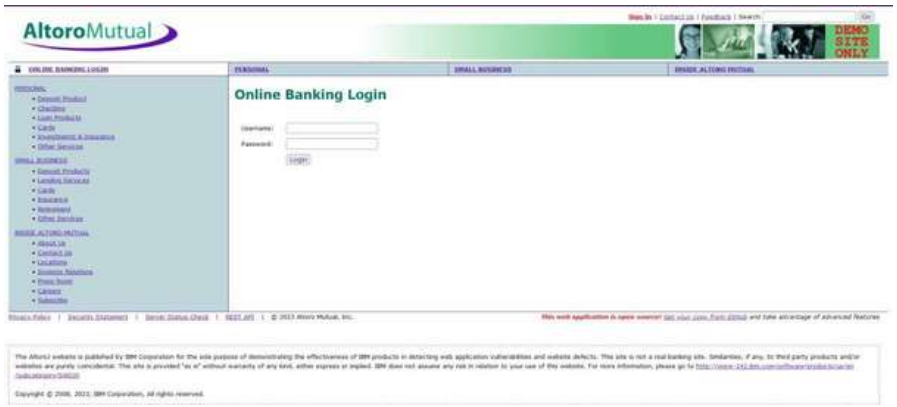
Vulnerabilityparameter:http://testfire.net/login.jsp

Stepstoreproduce:

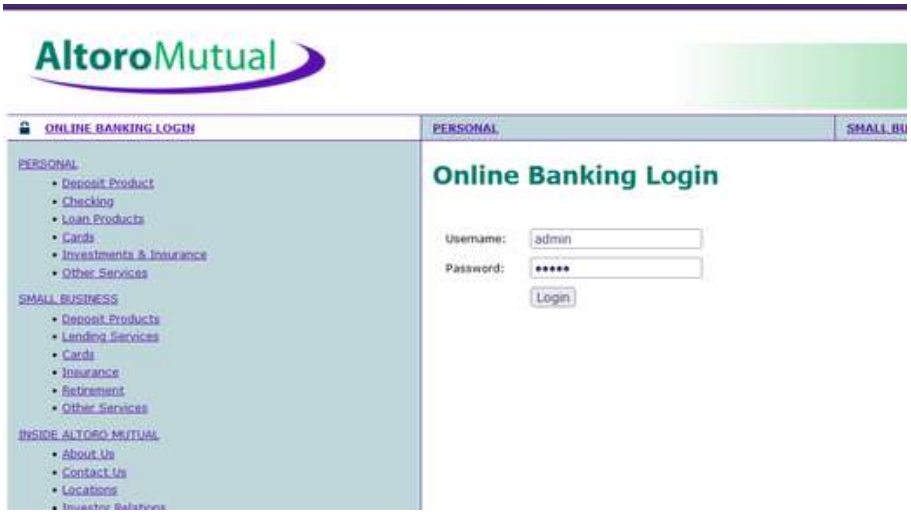
- AccesstheURL



- Nowwewilltrytosignintothiswebsitewithadminprivileges



- Also,wewillbeusingburpsuitetogetrequestsfromthewebsiteandknowadditionalinformation.
- Weuse‘admin’fortheusernameandpassword.



- Thisrequesthasbeenreceivedintheburpsuitewiththeusernameandpasswordaswellinclear text.

- Nowweclickonforwardrequestintheburpsuiteandthenwewillberedirectedtotheadminuser details. Here in the burp suite, we can clearly see the login details in clear text. this is the clear indication of the vulnerability which can lead to data breach, monitored, andmanipulated as well.

Recommendations:

- Educateusersandemployeesonsecuredatahandlingpractices,suchasrecognizingsecure websites (look for "https") and avoiding insecure Wi-Fi networks.
- Employdatamaskingorredactiontechniquestoreplacesensitivedatawithplaceholdersor cryptographic representations during transmission.
- ImplementencryptionfordataintransitUsesecureencryptionprotocolssuchasTLS/SSLto protect sensitive information during transmission.

- Usesecurecommunicationprotocolsfortransmittingdata,suchasHTTPSforwebapplications,and ensure that the selected protocols are kept up-to-date.

1. Vulnerabilityname:ClickJacking CWE: 1021

Description:Thewebapplicationdoesnotrestrictorincorrectlyrestrictsframeobjectsor UIlayersthat belong to another application or domain, which can lead to user confusion about which interface the user is interacting with.

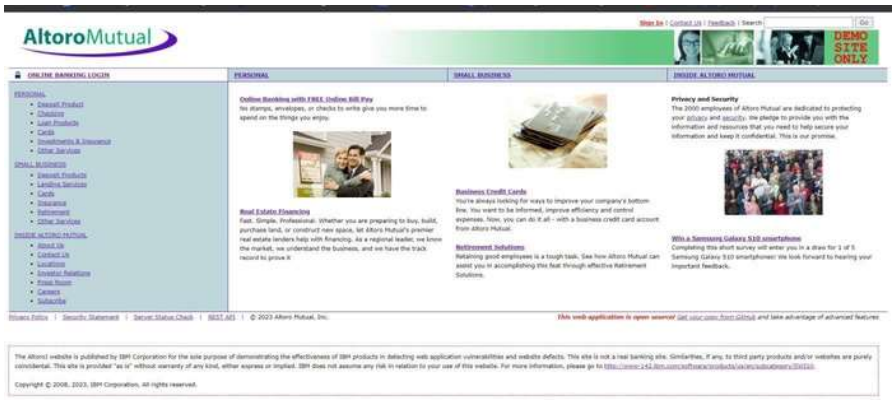
Business Impact: To effectivelyreduce the businessconsequences resulting from CWE-1021, organizations mustprioritize the implementation of protective measures,such as frame-busting code. Simultaneously,educatingusers onsafe browsing practices plays acrucial roleinpreventing clickjackingincidents.Additionally,routinesecurityassessments andtestingare pivotalforidentifying andmitigatingvulnerabilities associatedwithclickjacking.Theseactionsareofparamountimportance in upholding user trust, ensuring data protection, and safeguarding the organization's reputation.

Vulnerabilitypath:http://testfire.net/

Vulnerabilityparameter:http://testfire.net/

Stepstoreproduce:

- AccesstheURL



- ThentaketheURLanduseitforthehtmlcode
- wewillbewritingsomehtmlcodetoperformthisvulnerability.wewillbewritingthecodeinvs code for better flexibility and functionality.

```
<html>
<body>
<title>Click jacking vulnerability</title>
<h2>This website is vulnerable to clickjacking</h2>
<iframe  src="http://testfire.net/"></iframe>
</body>
</html>
```

- Afterthecodehasbeenwrittenthenwewillbeexecutingthecodeinthebrowser.

This website is vulnerable to clickjacking

- Fromthisimagewecanseethatthevulnerabilityhasbeenfound.

Recommendation:

- SettheX-Frame-OptionsHTTPresponseheadertodenyorsame-origintocontrolhowyoursite can be framed. This is supported by most modern browsers.
- Utilizeframe-bustingJavaScriptcodeinwebapplicationstopreventtheembeddingofyoursite within malicious iframes. This code can disrupt clickjacking attempts.
- ImplementaContentSecurityPolicytorestrictwhichdomainscanembedyoursiteiniframes. This can help prevent unauthorized framing.
- ImplementadditionalsecuritycontrolstopreventUIredressattacks,suchasclickjacking, within your web application.

1. Vulnerabilityname:webserverallowspasswordauto-completion CWE: 310

Description:

Weaknesses in this category are related to the design and implementation of data confidentiality and integrity. Frequently these deal with the use of encoding techniques, encryption libraries, and hashing algorithms.Theweaknessesinthiscategorycouldleadtoadegradationofthequalitydataiftheyarenot addressed.

Businessimpact:

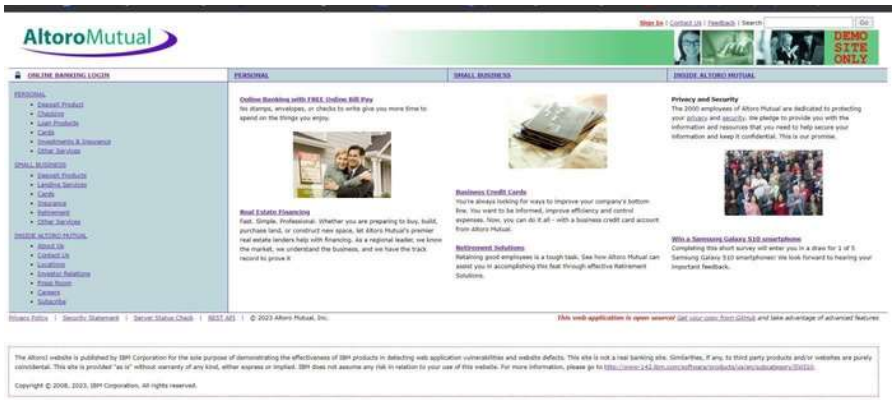
ToeffectivelylessenthebusinessconsequencesassociatedwithCWE-310,organizationsmustprioritizethe adoption of secure cryptographic practices. This entails ensuring proper password storage and robust encryptionkeymanagement.Simultaneously,conductingroutinesecurityassessmentsandtestingis pivotal in detecting and mitigating vulnerabilities related to cryptographic issues. Striving for compliance with pertinent data protection regulations and industry standards is equally essential. These actions are of paramountimportance inthe protectionof sensitivedata, the upholding of user trust,andthe preservation of the organization's esteemed reputation.

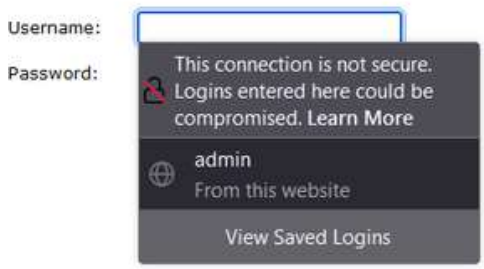
Vulnerabilitypath:http://testfire.net/

Vulnerabilityparameter:http://testfire.net/login.jsp

Stepstoreproduce:

- AccesstheURL





- Fromthisimagewecanseetheusernamesandthepasswordsgettingautofilled.Thisisa potential vulnerability as this can be a doorway for attackers.

Responsibilities:

- Implementsecurepasswordstoragemechanisms,suchasusingstrongandsaltedcryptographic hashing algorithms like bcrypt or scrypt.
- Implementrobustencryptionkeymanagementpractices,includingsecurekeystorage,keyrotati on, and access controls.
- Utilizewell-establishedandprovencryptographiclibrariesandalgorithmsforencryptionand decryption.
- Usesecureencryptionprotocols,likeTLS/SSL,fordatatransmissionovernetworkstoprotectdata in transit.

1. Vulnerabilityname:Cross-sitescripting(DOMbasedXSS) CWE: 79

OWASPcategory:A03:Injections

Description:Itoccurswhenamaliciousscriptisinjecteddirectlyintoavulnerablewebapplication.Refl ected XSS involves the reflection of a malicious script of a web application, onto a user's browser.

DOM-XSS: DOM stands for Document Object Model and is a programming interface for HTML and XML documents.Itrepresentsthatprograms canchangethedocumentstructure,styleandcontent.Awebpageis a document and this document can be either displayed in the browser window or as the HTML Source.

Business Impact: The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequently read back into the application and included in dynamic content. From an attacker's perspective, the optimal place to inject malicious content is in an area displayedtomanyusersorparticularlyinterestingusers.Interestinguserstypicallyhaveelevatedpriv ileges intheapplicationorinteractwithsensitivedatathatisvaluabletotheattacker.Ifoneoftheseusersexecu

tes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain access to sensitive data belonging to the user.

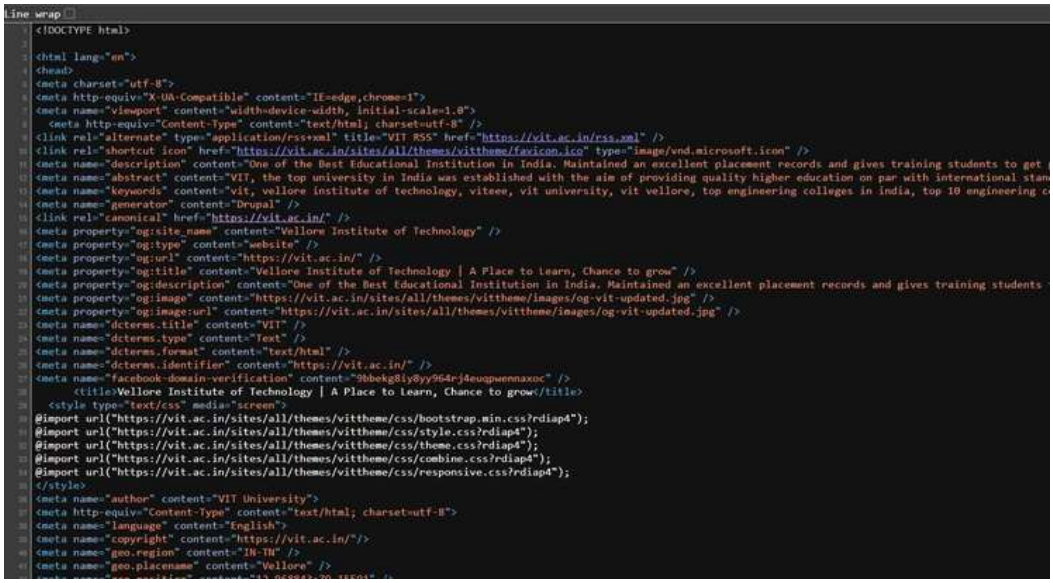
Vulnerabilitypath:https://vit.ac.in/

Vulnerabilityparameter:https://vit.ac.in/

StepstoReproduce:

- AccesstheURL

- WewilltrytoperformtheDOMXSSattackwhichisdisplayingthesourcecodeofthewebpage.
- Nowwecanaccessthesourcecodeofthewebpageintwowaysbyclickingontheinspectoptionorby simply pressing Ctrl + U.



- Manyprogramscanhelptoalterthissourcecodetofindvulnerablespots.

- So,gettingaccesstothesourcecodeofthewebpagecanleadtopotentialvulnerabilitiesasattackers can abuse the loop holes, exploits, vulnerabilities in the code and act accordingly.

Recommendation:

- Wheninteractingwithdatabases,useparameterizedstatementsorpreparedstatementstoavoid SQL injection, which can be a vector for XSS.
- Sanitize and validate alluserinputsand ensure that any data displayed on theweb page is properlyencoded. Use output encoding libraries or functions to prevent script injection.
- AvoidusingDOMmanipulationmethodsthatcanintroducevulnerabilities.BecautiouswithinnerHTML, document. Write, and other methods that can execute scripts.
- Considerusingwell-establishedJavaScriptframeworksandlibrariesthatincludebuilt-insecurity features to prevent DOM XSS.

1. Vulnerabilityname:JQuery1.2<3.5.0MultipleXSS

CWE:79

OWASPcategory:A03:Injections

Description: It occurs when a malicious script is injected directly into a vulnerable web application. ReflectedXSSinvolvesthereflectionofamaliciousscriptofawebapplication,ontoauser'sbrowser.

StoredXSS(PersistentXSS):Inthistypeofattack,themaliciousscriptispermanentlystoredonaserver or in a database, often in user-generated content like comments or forum posts. When other users view the affectedcontent, the script executes intheir browsers, potentiallycompromising their data orsessions.

ReflectedXSS: Reflected XSS occurs whenthe maliciousscript is embedded ina URLandimmediately executedwhenavictimclicksonamanipulatedlink.Thescriptisnotstoredonaserverbutisreflectedoff a web application, making it a one-time attack.

DOM-based XSS: DOM stands for Document Object Model and is a programming interface for HTML and XML documents. It represents that programs can change the document structure, style and content. A webpageisadocumentandthisdocumentcanbeeitherdisplayedinthebrowserwindoworastheHTML Source.

Business Impact: The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequently read back into the

applicationandincluded in dynamic content. From anattacker's perspective, the optimal place to inject malicious content is in an area displayed to many users or particularly interesting users. Interesting users typically have elevated privileges intheapplicationorinteractwith sensitive datathatis valuable totheattacker.Ifoneof these usersexecutesmaliciouscontent,theattackermaybeabletoperform privilegedoperations onbehalfofthe user or gain access to sensitive data belonging to the user.

Vulnerabilitypath:https://vit.ac.in/

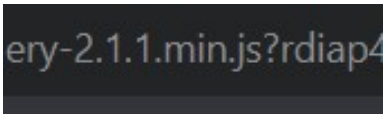
Vulnerabilityparameter:https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js?rdiap4

StepstoReproduce:

- AccesstheURL

- TrytoaccesstheURLhttps://vit.ac.in/sites/all/themes/vittheme/js/jquery-.Thiswillleadustothe webpage with jquery script in it.

- Wecanalsoseethejqueryversionthathasbeenusedinthewebsite



- Wecanaccessthesourcecodeofthejqueryscriptthathasbeenusedinmakingthewebsite,whichca n lead to multiple potential threats

Recommendation:

  - Themostimportantrecommendationistoupdatetothelatestversionofj Query.Newerversio ns typically include security patches, bug fixes, and performance improvements.
  - StayvigilantaboutjQueryupdatesandsecurityannouncements.Subscribetorelevantsecurit y mailing lists or forums to receive notifications about new releases.
  - A Content Security Policy(CSP) can help mitigate various types of client-sidevulnerabilities, includingCross-SiteScripting(XSS).ConsiderimplementingaCSPinyourwebapplicationto restrict the sources from which scripts can be loaded.
  - If updating jQuery is not immediately possible, review your code for potential security issues. Ensurethatyouareescapingorsanitizinguserinputsandthatyouareusingsafecodingpractic esto prevent XSS and other security vulnerabilities.

1. Vulnerabilityname:InformationExposure(WebServerHTTPHeaderInternalIPDisclosure)

   CWE: 200

Description:Theproductexposessensitiveinformationtoanactorthatisnotexplicitlyauthorizedtoha ve access to that information.

Business Impact: To effectively reduce the business consequences associated with CWE-200, organizations must prioritize the implementation of robust data access controls, secure data handling practices, and privacy protection measures. Regular security assessments and testing are instrumental in detecting and rectifying vulnerabilities related to information exposure. Furthermore,strictadherence to data protection regulations and industry standards is indispensable. These actions are of paramount importance in the protectionofsensitivedata,thepreservationofusertrust,andtheupholdingoftheorganization'sestee med reputation.

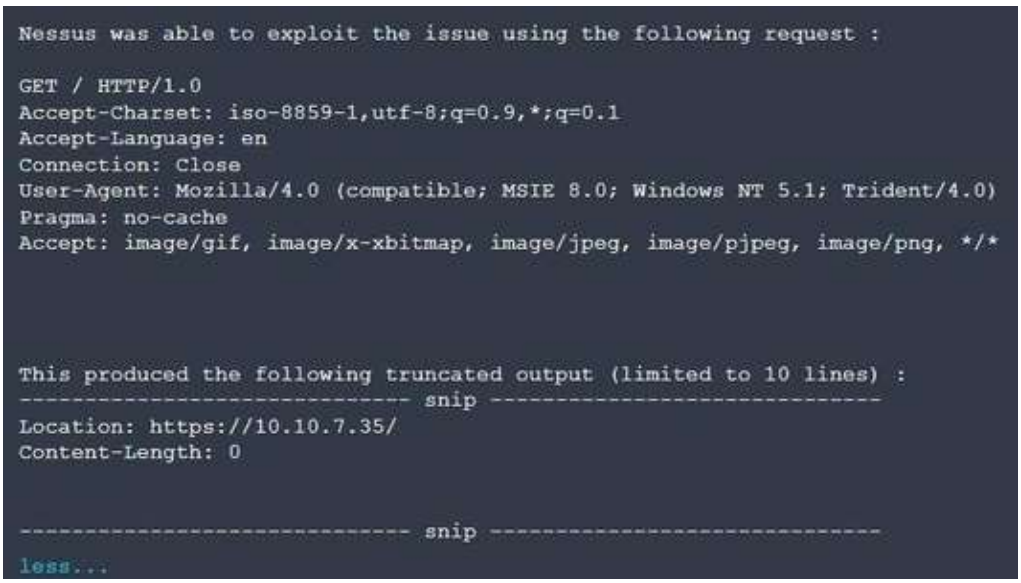
Vulnerability path: https://vit.ac.in/ Vulnerabilityparameter:https://vit.ac.in/ Steps to

Reproduce:

- AccesstheURL

- Wewillbeusingatooltoperformascanonthiswebsite.(NessusScanner)

- Throughthistoolwecanseethevulnerabilityinthescanalongwithdetailedinformationregarding that vulnerability.



- NowthisimagetellsustheinternalIPaddressofthetargetwebsite,theattackerscaneasilyexploitthe website using the ip address.

Recommendation:

- Carefullyreviewyourwebserver'sconfigurationfiles(e.g.,Apache'shttpd.conf,Nginx'snginx.conf)to identify anywhere internal IP addresses are inadvertently included in HTTP response headers.
- RemoveorreplaceanyinternalIPaddressesintheserverconfigurationfileswithappropriate placeholders or public IP addresses.
- Ifyouuseproxyserversorloadbalancers,ensurethattheyareconfiguredtohideinternalIPaddresses and only expose public IP addresses instances in HTTP headers.
- ReviewandconfigureHTTPresponseheaders(e.g.,Server,X-Powered-By)tolimittheexposureof server and technology details, reducing the potential for disclosing internal IP addresses.

1. Vulnerabilityname:InformationExposure(SSL(MultipleIssues)) CWE: 200

Description:Theproductexposessensitiveinformationtoanactorthatisnotexplicitlyauthorizedtohave access to that information.

Business Impact: To effectively reduce the business consequences arising from SSL issues,organizations must give utmost priority to establishing a secure SSL/TLS configuration, conducting frequent security assessments and testing. Adhering to data protection regulations and industry standards is imperative. Theseactionsplayapivotalroleinsafeguardingsensitivedata,upholdingusertrust,andsafeguardingthe organization's esteemed reputation.

Vulnerabilitypath:https://vit.ac.in/

Vulnerabilityparameter:https://vit.ac.in/

StepstoReproduce:

-

- AccesstheURL

- Wewillbeusingatooltoperformascanonthiswebsite.(NessusScanner)

- Throughthistoolwecanseethevulnerabilityinthescanalongwithdetailedinformationregarding that vulnerability.

INFO SSL Certificate Information

Description

This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate.

Output

```
Subject Name:

Common Name: *.vit.ac.in

Issuer Name:

Country: GB
State/Province: Greater Manchester
Locality: Salford
Organization: Sectigo Limited
Common Name: Sectigo RSA Domain Validation Secure Server CA

Serial Number: 46 53 67 B6 23 C5 BE EE B9 6E E2 C0 5F 46 C9 F7

Version: 3

Signature Algorithm: SHA-256 With RSA Encryption

Not Valid Before: Sep 04 00:00:00 2023 GMT
Not Valid After: Aug 03 23:59:59 2024 GMT

Public Key Info:

Algorithm: RSA Encryption
Key Length: 2048 bits
```

- Nowthisimagetellsusthetypeofencryptionusedinthetargetwebsitewiththepublickeydetailsas well.

- Throughthiswecanunderstandwhatdifferenttypesofencryptionsareusedinthewebsite.

```
Here is the list of SSL CBC ciphers supported by the remote server :

  High Strength Ciphers (>= 112-bit key)

    Name                        Code            KEX          Auth     Encryption             MAC
    ----------------------      ----------      ---          ----     --------------------   ---
    ECDHE-RSA-CAMELLIA-CBC-128  0xC0, 0x76      ECDH         RSA      Camellia-CBC(128)      SHA256
    ECDHE-RSA-CAMELLIA-CBC-256  0xC0, 0x77      ECDH         RSA      Camellia-CBC(256)      SHA384
    DHE-RSA-AES128-SHA          0x00, 0x33      DH           RSA      AES-CBC(128)           SHA1
    DHE-RSA-AES256-SHA          0x00, 0x39      DH           RSA      AES-CBC(256)           SHA1
    DHE-RSA-CAMELLIA128-SHA     0x00, 0x45      DH           RSA      Camellia-CBC(128)      SHA1
    DHE-RSA-CAMELLIA256-SHA     0x00, 0x88      DH           RSA      Camellia-CBC(256)      SHA1
    DHE-RSA-SEED-SHA            0x00, 0x9A      DH           RSA      SEED-CBC(128)          SHA1
    ECDHE-RSA-AES128-SHA        0xC0, 0x13      ECDH         RSA      AES-CBC(128)           SHA1
    ECDHE-RSA-AES256-SHA        0xC0, 0x14      ECDH         RSA      AES-CBC(256)           SHA1
    AES128-SHA                  0x00, 0x2F      RSA          RSA      AES-CBC(128)           SHA1
    AES256-SHA                  0x00, 0x35      RSA          RSA      AES-CBC(256)           SHA1
    CAMELLIA128-SHA             0x00, 0x41      RSA          RSA      Camellia-CBC(128)      SHA1
    CAMELLIA256-SHA             0x00, 0x84      RSA          RSA      Camellia-CBC(256)      SHA1
    SEED-SHA                    0x00, 0x96      RSA          RSA      SEED-CBC(128)          SHA1
    DHE-RSA-AES128-SHA256       0x00, 0x67      DH           RSA      AES-CBC(128)           SHA256
    DHE-RSA-AES256-SHA256       0x00, 0x6B      DH           RSA      AES-CBC(256)           SHA256
    DHE-RSA-CAMELLIA128-SHA256  0x00, 0xBE      DH           RSA      Camellia-CBC(128)      SHA256
    DHE-RSA-CAMELLIA256-SHA256  0x00, 0xC4      DH           RSA      Camellia-CBC(256)      SHA256
    ECDHE-RSA-AES128-SHA256     0xC0, 0x27      ECDH         RSA      AES-CBC(128)           SHA256
    ECDHE-RSA-AES256-SHA384     0xC0, 0x28      ECDH         RSA      AES-CBC(256)           SHA384
    RSA-AES128-SHA256           0x00, 0x3C      RSA          RSA      AES-CBC(128)           SHA256
    RSA-AES256-SHA256           0x00, 0x3D      RSA          RSA      AES-CBC(256)           SHA256
    RSA-CAMELLIA128-SHA256      0x00, 0xBA      RSA          RSA      Camellia-CBC(128)      SHA256
    RSA-CAMELLIA256-SHA256      0x00, 0xC0      RSA          RSA      Camellia-CBC(256)      SHA256
```

Recommendation:

- ConfigureyourwebservertousethelatestandstrongestencryptionprotocolsSuchasTLS1.2or higher. Disable outdated and insecure protocols like SSLv3.
- ImplementPerfectForwardSecrecytoensurethatevenifthepriveatekeyiscompromised, previously recorded encrypted traffic remains secure.
- Safeguardyourprivatekeysbystoringthemsecurelyandensuringtheyarenotaccessible to unauthorized parties.

1. Vulnerabilityname:InformationExposure(HTTP(MultipleIssues)) CWE: 200

Description:Theproductexposessensitiveinformationtoanactorthatisnotexplicitlyauthorizedtohave access to that information.

BusinessImpact:ToeffectivelyreducethebusinessrepercussionsofHTTPissues,organizationsmust place astrong emphasis onongoingmonitoring andenhancementoftheirweb services.Consistentperformance testing and security assessments, coupled with proactive maintenance, are indispensable to ensure a seamlessandsecure online presence. Furthermore, offering timely and helpful customer support and transparent communication when HTTP issues arise is instrumental in mitigating adverse effects on user trust and satisfaction.

Vulnerabilitypath:https://vit.ac.in/

Vulnerabilityparameter:https://vit.ac.in/

StepstoReproduce:

- AccesstheURL

- Wewillbeusingatooltoperformascanonthiswebsite.(NessusScanner)

Search Vulnerabilities | 2 Vulnerabilities

Sev	CVSS	VPR	Name	Family
INFO			HyperText Transfer Protocol (HTTP) Informa...	Web Servers
INFO			HTTP Server Type and Version	Web Servers

INFO HyperText Transfer Protocol (HTTP) Information

Description

This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc...

This test is informational only and does not denote any security problem.

```
Response Code : HTTP/1.1 307 Moved Temporarily

Protocol version : HTTP/1.1
SSL : no
Keep-Alive : no
Options allowed : (Not implemented)
Headers :

  Location: https://vit.ac.in/
  Content-Length: 0

Response Body :
```

- Fromtheaboveimagewecanseethedetailsofprotocolversionofthewebsiteanditsstatus.

INFO HTTP Server Type and Version

Description

This plugin attempts to determine the type and the version of the remote web server.

```
The remote web server type is :

Apache
```

- Wecanseethetypeofremotewebserverhere.

- Allthisinformationcanleadtomultiplepotentialthreatssuchasdatabreachesbyhackers.

Recommendation:

  - Minimizetheuseofunnecessaryredirectsastheycanincreasepageloadtimes.Use301 (permanent) redirects for consistent content.
  - Regularlycheckforbrokenlinks(404errors)andfixthemtoensureusersfindthecontent theyare looking for.
  - ProperlyconfigureCORStocontrolwhichdomainsareallowedtomakerequeststoyours erver.
  - MigrateyourwebsitefromHTTPtoHTTPStoensuresecuredatatransmission.Thisisess entialfor user trust and search engine ranking.

1. Vulnerabilityname:OSIdentificationFailed CWE: 200

Description:OSidentificationfailedreferstotheinabilityofasystemorsoftwaretoaccuratelyrecogniz ethe operating system running on a device or network. This issue can result from various factors such as misconfigurations,networkissues,orcompatibilityproblems.ThefailuretoidentifytheOScorrectlyc anlead to security vulnerabilities, hindered software updates, and potential operational disruptions. Resolving this issue promptly is crucial to ensure accurate security measures and the smooth functioning of the system or network.

Business Impact:Itmaylead to operationalinefficiencies, potentialsecurityvulnerabilities, non-compliance with industry regulations, and a possible loss of customer trust. Such failures could result in downtime, compromised data security, regulatory penalties, and damage to the company's reputation, potentially leadingtofinanciallosses anddecreasedmarketcompetitiveness.Resolvingthisissuepromptlyiscrucialto mitigate these risks and maintain the smooth functioning of the organization.

Vulnerability path: https://vit.ac.in/ Vulnerabilityparameter:https://vit.ac.in/ Steps to

Reproduce:

- AccesstheURL

- Wewillbeusingatooltoperformascanonthiswebsite.(NessusScanner)

INFO **OS Identification Failed**

Description

Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. Unfortunately, though, Nessus does not currently know how to use them to identify the overall system.

```
If you think these signatures would help us improve OS fingerprinting,
please send them to :

  os-signatures@nessus.org

Be sure to include a brief description of the device itself, such as
the actual operating system or product / model names.


SSLcert:!:i/CN:Sectigo RSA Domain Validation Secure Server CAi/O:Sectigo
Limiteds/CN:*.vit.ac.in
02ed800c9e7f764615d7e9ffd74b643a6cace446

SinFP:!:
   P1:B10113:F0x12:W65535:O0204ffff:M496:
   P2:B10113:F0x12:W65535:O0204ffff010303030101040201010 80affffffff44454144:M1300:
   P3:B00000:F0x00:W0:O0:M0
   P4:190701_7_p=80R
```

- FromtheaboveimageWecanseethedetailsofSSLCertificateInformationandSinFPInformation.
- IfitisreleasedwithoutproperauthorizationitcanleadtoseriousconsequencessuchasincreasedvulnerabilitytocyberattackspotentialdatabreachesprivacyviolationsandlegalrepercussionsAllthisinformationcanleadtomultiplepotentialthreatssuchasdatabreachesbyhackers.

Recommendations:

- Employrobustdataencryptionmethodsforbothdataintransitandatrest.
- Implementstrictaccesscontrolsandauthenticationprotocolstolimitunauthorizedaccess.
- Usesecurecommunicationchannelssuchasencryptedemailandfiletransferprotocols.
- Providecomprehensivetrainingto employeeson datasecuritybestpractices.
- Conduct regularsecurityauditsandassessmentstoidentifyandaddressvulnerabilitiespromptly.

- Ensurecompliancewithrelevantdataprotectionregulationsandhaveawell-definedincident response plan in place.

NESSUSSCANREPORT:

testfire.net

0	0	3	1	24
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities — Total: 28

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
MEDIUM	6.5	-	142960	HSTS Missing From HTTPS Server (RFC 6797)
MEDIUM	6.5	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	157288	TLS Version 1.1 Protocol Deprecated
LOW	3.7	4.5	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
INFO	N/A	-	46180	Additional DNS Hostnames
INFO	N/A	-	39446	Apache Tomcat Detection
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	10919	Open Port Re-check
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	95631	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported

INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	10287	Traceroute Information

* indicates the v3.0 score was not available; the v2.0 score is shown

vit.ac.in

0	0	1	1	26
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 28

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
MEDIUM	6.1	5.7	136929	JQuery 1.2 < 3.5.0 Multiple XSS
LOW	3.1	2.2	10759	Web Server HTTP Header Internal IP Disclosure
INFO	N/A	-	48204	Apache HTTP Server Version
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	106658	JQuery Detection
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	42823	Non-compliant Strict Transport Security (STS)
INFO	N/A	-	50350	OS Identification Failed
INFO	N/A	-	66334	Patch Report
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites

INFO	N/A	-	22964	Service Detection
INFO	N/A	-	42822	Strict Transport Security (STS) Detection
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	100669	Web Application Cookies Are Expired
INFO	N/A	-	10386	Web Server No 404 Error Code Check
INFO	N/A	-	10302	Web Server robots.txt Information Disclosure

* indicates the v3.0 score was not available; the v2.0 score is shown

"With the Nessus scan report now at our disposal, we're equipped withcritical data on the existing vulnerabilitiesandpotentialthreats.Thisinvaluableinformationwillserveasafoundationforourproject planning phase, as we chart the course to develop our AI-driven incident response platform with a well- informed strategy and timeline."

Stage–2

Overview:-

AnoverviewofaNessusscantypicallyinvolvesthefollowingkeystepsandaspects:

1. Preparation:Define Objectives: Determine the scope and objectives of the scan. What systems or networks do you want to assess, and what specific vulnerabilities are you looking for?

SystemAccess:Ensurethatyouhavethenecessarypermissionsandaccessrightstoscanthetargetsystems or networks.

1. Configuration:Set Up Scan Policy: Create a scan policy that defines the parameters of the scan, such as the types of vulnerabilities to check for, scanning frequency, and specific configurations.

DefineTargetAssets:SpecifytheIPaddresses,hostnames,ornetworkrangesofthesystemsyouwanttoscan.

1. Scanning:Initiate Scan: Start the Nessus scan using the configured policy and target assets. Nessus will systematically scan the target systems for vulnerabilities based on its plugins and policies.

1. Vulnerability Identification:Nessus performs a comprehensive assessment, checking for vulnerabilities, misconfigurations,openports,andothersecurityissues.Asthescanprogresses,itcategorizesvulnerabilities by severity, making it easier to prioritize remediation efforts.

1. Reporting:Nessusgeneratesdetailedreportsthatlistthevulnerabilitiesdiscoveredduringthescan.Reports typicallyincludeinformationabouttheseverityofeachvulnerability,recommendedactionsforremediation, and supporting evidence. These reports can be customized and exported in various formats, such as PDF, HTML, or CSV.

1. Remediation:Review Findings: IT and security teams review the Nessus scan reports to prioritize and address the identified vulnerabilities.

RemediationSteps:Takecorrectiveactionstofixormitigatethevulnerabilities.Thismayinvolveapplying patches, changing configurations, or implementing security measures.

1. Follow-up:RegularScanning:ConductperiodicNessusscanstocontinuouslymonitorthesecuritypostureof the systems and networks. This helps identify new vulnerabilities and track progress in mitigating existing ones.

Integration:IntegrateNessuswithothersecuritytoolsorworkflowstoautomatethevulnerability management process and streamline the response to new findings.

1. Compliance Auditing (if applicable):If compliance checks are part of your scan policy, review compliance results and take actions to ensure systems meet the required standards and regulations.

1. Documentation:Maintain records of scan results, remediation efforts, and compliance checks for audit and reporting purposes.

1. UserTraining:EnsurethatyourITandsecurityteamsaretrainedinusingNessuseffectivelyandinterpreting scan results.

Nessus scans are a critical component of proactive security, helping organizations identify and address vulnerabilities in their IT infrastructure to reduce the risk of security breaches and data compromises. The frequency and depth of scans can vary depending on an organization's security strategy and requirements.

Nessus is a popular vulnerability scanning tool used for identifying security weaknesses in computer systems and networks. It is widely utilized by security professionals and organizations to assess the security posture of

theirsystems andto proactivelyidentifypotentialvulnerabilities thatcouldbeexploitedbyattackers.Here's what I understand about Nessus scans:

1. Vulnerability Assessment: Nessus performs a vulnerability assessment by scanning target systems or networks to identify security issues, such as missing patches, misconfigurations, weak passwords, and other potential weaknesses that could be exploited by attackers.
2. NetworkScanning:Nessuscanscanawiderangeofnetworkdevices,includingservers,routers,switches, firewalls, and more. It examines network services, open ports, and software running on target systems.
3. Plugin Architecture: Nessus uses a plugin-based architecture, allowing it to check for a wide variety of vulnerabilities.These plugins areregularlyupdatedtoinclude the latestsecuritychecks andsupportfor new vulnerabilities.

1. Compliance Auditing: It can also be used to assess systems against various compliance standards and regulatory requirements, helping organizations ensure that their systems meet specific security standards, like PCI DSS or CIS benchmarks.
2. Customization: Nessus scans can be customized to suit the specific needs of an organization. Users can define scan policies, select the target systems, and specify the types of vulnerabilities to scan for.
3. Reporting:Nessusprovidesdetailedreportsthathighlightvulnerabilities,theirseverity,andremediation recommendations. These reports are essential for IT and security teams to prioritize and address vulnerabilities.

1. Scanning Frequency: Organizations often perform regular Nessus scans to continuously monitor and improve their security posture. This is crucial for staying ahead of evolving threats and vulnerabilities.
2. Integration: Nessus can be integrated with othersecurity tools and platforms, allowing organizations to automate the scanning process and streamline their vulnerability management.

1. Licensing:Nessusoffersbothfreeandcommercialversions.Thefreeversionislimitedinitsfunctionality, while the commercial version provides more features and support.
2. User-FriendlyInterface:Nessusoffersaneasy-to-useweb-basedinterface,makingitaccessibletoawide range of users, from security experts to less experienced IT professionals.

It's important to note that Nessus is a valuable tool for identifying vulnerabilities, but it doesn't fix these vulnerabilities itself. It's up to the organization's IT and security teams to take the necessary steps to remediate the identified issues to enhance their security.

S.No	VulnerabilityName	Severity	Plugins
1.	Cross-sitescripting(stored)	Low	WebapplicationScanner
2.	BrokenAccessControl	Medium	SSHweakHMACAlgorithms Supported

3.	SQL Injection	Medium	N/A
4.	BrokenAuthentication	Low	HSTSMissingfromServer
5.	InsecureDirectObjectReference	Info	ServiceDetection
6.	SecurityMisconfiguration	Low	SSLcipher BlockChainingcipher suites
7.	Cross-SiteRequestForgery	Low	HTTPForm-BasedAuthentication Detected
8.	CleartextTransmissionof SensitiveInformation	Medium	CleartextTransmissionofSensitive Information over HTTP
9.	ClickJacking	Info	HTMLRenderingLayerVulnerability
10.	webserverallowspasswordauto-completion	Low	SSL/TLS Diffie-Hellman Modulus<=1024bits(Logjam)

Target Website: testfire.net TargetIPAddress:54.83.41.36 Report:

1. VULNERABILITYNAME:Crosssitescripting(stored) SEVERITY: Low

PLUGIN:webapplicationscanner PORT: N/A

DESCRIPTION: It occurs when a malicious script is injected directly into a vulnerable web

application.ReflectedXSSinvolvesthereflectionofamaliciousscriptofawebapplication,onto a user's browser.

SOLUTION:

- Wheninteractingwithdatabases,useparameterizedstatementsorpreparedstatementsto avoid SQL injection, which can be a vector for XSS.
- Sanitizeandvalidatealluserinputsandensurethatanydatadisplayedonthewebpage properlyencoded.Useoutputencodinglibrariesorfunctionstopreventscriptinjection.

BUSINESS IMPACT: The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequently read back into the application andincluded in dynamic content. From an attacker'sperspective, the optimal place to inject malicious content is in an area that is displayed to either many users or particularly interestingusers.Interestinguserstypicallyhaveelevatedprivilegesintheapplicationorinteract withsensitivedatathatisvaluabletotheattacker.Ifoneoftheseusersexecutesmaliciousconte nt, the attacker may be able to perform privileged operations on behalf of the user or gain access to sensitive data belonging to the user.

1. VULNERABILITYNAME:Brokenaccesscontrol SEVERITY: medium

PLUGIN:SSHweakHMACAlgorithmssupported PORT: N/A

DESCRIPTION: When access control checks are not applied consistently - or not at all - users are abletoaccessdataorperformactionsthattheyshouldnotbeallowedtoperform.Thiscanleadto a wide range of problems, including information exposures, denial of service, and arbitrary code execution.

SOLUTION:

- Ensurethattheapplicationhasarobustauthenticationandauthorizationmechanism in place. Users should be authenticated before any sensitive actions are performed, and authorization checks should be conducted to verify that users have the necessary permissions for the requested operation.
- EnsurethatsessionmanagementissecureUsestrongsessionIDs,enforcesessiontimeouts, and regenerate session tokens after login. Implement session fixationprotection to prevent session hijacking.

BUSINESSIMPACT:wide-rangingbusinessimpact,includingfinanciallosses,reputationdamage, legal consequences, operational disruption, and loss of customer trust. Addressing this vulnerability is crucial to protect the organization and its stakeholders from these potential negative effects.

1. VULNERABILITYNAME:SQLinjection

SEVERITY:medium

PLUGIN:N/A(typicallywouldbeasecuritytestingtool) PORT: port 80/443

DESCRIPTION:TheproductconstructsallorpartofanSQLcommandusingexternallyinfluenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component.

SOLUTION:

- If parameterized statements are not feasible, use proper input validation and escaping mechanismstosanitizeuserinputsbeforetheyareusedinSQLqueries.Thishelpsprevent malicious code injection.
- UtilizestoredproceduresfordatabaseoperationsThiscanhelpseparateSQLcodefrom application code and reduce the risk of SQL injection.
- Implementstrictinputvalidationforalluserinputs,ensuringthatdataadherestothe expected format and structure.

BUSINESSIMPACT:Insummary,itiscrucialtounderscorethatCWE-89,knownasSQLInjection, can exert a profound and diverse business impact. This encompasses critical facets such as data breaches, financial setbacks, harm to reputation, legal ramifications, and operational turmoil.

Hence, the imperative of preventing and remedying SQL injection vulnerabilities cannot be overstated,asitisindispensableforfortifyingthesecurityandcontinuityofanorganization's applications and data.

1. VULNERABILITYNAME:Brokenauthentication SEVERITY: Low

PLUGIN:HSTSMissingfromHTTPSServer(pluginid:142960) PORT: port 443

DESCRIPTION:Thesystem'sauthorizationfunctionalitydoesnotpreventoneuserfromgaining access to another user's data or record by modifying the key value identifying the data.

SOLUTION:

- Implementstrongauthenticationmechanisms,suchasmulti-factorauthentication(MFA)or two-factorauthentication(2FA),toensurethatonlyauthorizeduserscanaccessthesystem.
- Implement proper authorization controls to ensure that users have the necessary permissionstoaccessspecificfunctionsordata.Userole-basedaccesscontrol(RBAC)to manage user privileges effectively.
- Deployintrusiondetectionandpreventionsystems(IDS/IPS)tomonitorandblock suspicious activities related to authentication and authorization.

BUSINESSIMPACT:To effectivelymitigate thebusinessimpact ofCWE-285, itisimperative that organizations place a strong emphasis on bolstering their authentication and session management practices. This shouldencompass the adoptionofmulti-factorauthentication, the secure storage of credentials, meticulous session handling, and a commitment to conducting routine security assessments and testing. The rectification of these vulnerabilities stands as a critical imperative, safeguardingsensitivedata,useridentities,andtheorganization'soverarchingsecuritystatureand reputation.

1. VULNERABILITYNAME:InsecureDirectobjectReference SEVERITY: Info

PLUGIN:ServiceDetection(pluginid:22964) PORT: port 80/443

DESCRIPTION: Insecure Direct Object Reference (IDOR) is a vulnerability that arises when attackers can access or modify objects by manipulating identifiers used in a web application's URLsorparameters.Itoccursduetomissingaccesscontrolchecks,whichfailtoverifywhether a user should be allowed to access specific data.

SOLUTION:

- Utilizeparameterizedqueriesorpreparedstatementswheninteractingwithdatabases.This prevents user-controlled input from being executed as SQL code.
- ImplementaContentSecurityPolicytomitigatetheriskofcross-sitescripting(XSS)attacks, which can be used to execute unauthorized queries.

- Implementaccountlockoutmechanismsthattemporarilysuspendaccountsafterasp ecified number of unauthorized access attempts to prevent brute force attacks.

BUSINESS IMPACT:To effectively mitigate the business impact of CWE-639, organizations must makeitatopprioritytofortifytheiraccesscontrolandauthorizationmechanisms. Thisentailsthe implementation of robust security measures, the regular conduct of comprehensive security assessments, and the deployment of intrusion detection systems to promptly identify and counter unauthorizedaccessattempts.Thesemeasuresstandascriticalinthedefenceofsensitivedata ,the overall security of systems, and the preservation of the organization's esteemed reputation.

1. VULNERABILITYNAME:SecurityMisconfiguration

SEVERITY:low

PLUGIN:SSLcipherBlockchainingciphersuites PORT: port 443

DESCRIPTION:Theproductspecifiespermissionsforasecurity-criticalresourceinawaythat allows that resource to be read or modified by unintended actors.

SOLUTION:

- Implementachangemanagementprocesstodocumentandreviewallchangestosyst em configurations. This helps prevent unauthorized or unintended alterations.
- Followsecurityguidelinesprovidedbysoftwareandhardwarevendorstoensuresec ure configurations.
- Regularlyperformcompliancechecksagainstindustrystandardsandregulationstoe nsure that configurations remain in compliance with security requirements.

BUSINESS IMPACT:To effectively lessen the business consequences stemming from CWE-732, organizations must place a strong emphasis on bolstering their configuration management practices. This involves the establishment of secure default settings, the routine conduct of comprehensive security evaluations, and the deployment of intrusion detection systems to promptly detect and address misconfigurations and vulnerabilities. These actions are of paramountimportanceinsafeguardingsensitivedata,fortifyingsystemsecurity,andpreserv ing the organization's esteemed reputation.

1. VULNERABILITYNAME:Cross-SiteRequestForgery SEVERITY: Low

PLUGIN:HTTPForm-BasedAuthenticationDetected PORT: port 8080/443

DESCRIPTION: Cross-Site Request Forgery (CSRF) is an attack that forces an end user to execute unwantedactionsonawebapplicationinwhichthey'recurrentlyauthenticated.Withalittlehelp ofsocialengineering(suchassendingalinkviaemailorchat),anattackermaytricktheusers ofa web application into executing actions of the attacker's choosing. If the victim is a normal user, a successful CSRF attack can force the user to perform state changing requests like transferring funds, changing their email address, and so forth. If the victim is an administrative account, CSRF can compromise the entire web application.

SOLUTION:

- Implement Synchronizer Token Patterns to include unique, randomly generated tokens in eachHTTPrequestandvalidatethesetokensontheserversidetoverifytheauthenticityof the request.
- UtilizetheSameSiteattributeincookiestorestricttheirusagetosame-siterequestsonly, preventingthemfrombeingsentalongwithcross-site requests andeffectivelymitigating CSRF attacks.

- Utilizeframework-specificprotectionsandsecurityfeaturestopreventCSRFattacks.Many modern web frameworks have built-in mechanisms and libraries for handling CSRF vulnerabilitieseffectively.
- Implement a Content Security Policy to restrict the sources from which various types of contentcanbeloaded.Byspecifyingthetrustedsourcesofcontent,youcanminimizetherisk of malicious code execution and reduce the likelihood of successful CSRF attacks.

BUSINESS IMPACT:To effectively reduce the business repercussions of CWE-352, organizations mustprioritizesecurecodingpractices,includingtheincorporationofanti-CSRFtokens,whilealso conducting routine security assessments and testing to detect and rectify CSRF vulnerabilities.

Furthermore, educatingusersonsecurebrowsingpractices ispivotalinpreventingCSRF attacks. Theseactionsareofparamountimportanceintheprotectionofdataandinupholdingthetrust of customers and partners.

1. VULNERABILITYNAME:CleartextTransmissionofSensitiveInformation SEVERITY:

   Medium

PLUGIN:CleartextTransmissionofSensitiveInformationoverHTTP PORT: port 443

DESCRIPTION: The product transmits sensitive or security-critical data in cleartext in a communicationchannelthatcanbesniffedbyunauthorizedactors.Manycommunicationchannels canbe"sniffed"(monitored)byadversariesduringdatatransmission.Forexample,innetworking, packets cantraverse manyintermediarynodesfromthe source to the destination, whether across the internet, an internal network, the cloud, etc. Some actors might have privileged access to a networkinterfaceoranylinkalongthechannel, suchasarouter, buttheymightnot beauthorized to collect the underlying data. As a result, network traffic could be sniffed by adversaries, spilling security-critical data.

SOLUTION:

- Educateusersandemployeesonsecuredatahandlingpractices,suchasrecognizingsecure websites (look for "https") and avoiding insecure Wi-Fi networks.
- Employdatamaskingorredactiontechniquestoreplacesensitivedatawithplaceholdersor cryptographic representations during transmission.
- Implementencryptionfordataintransit.UsesecureencryptionprotocolssuchasTLS/SSLto protect sensitive information during transmission.
- Usesecurecommunicationprotocolsfortransmittingdata,suchasHTTPSforweb applications, and ensure that the selected protocols are kept up to date.

BUSINESS IMPACT: To effectively reduce thebusiness consequences associated with CWE-319, organizations must prioritize the adoption of secure data transmissionpractices. Thisincludesthe utilizationofencryptionandrobust,secureprotocols.Theroutineconductofsecurityassessments and testing is pivotal in pinpointing and remedying vulnerabilities linked to data transmission.

Furthermore, the education of users on secure data handling practices plays a vital role in proactivelypreventingdataexposureincidents.Theseactionsareofparamountimportanceinthe protection of sensitive data and in preserving the trust of both customers and partners.

1. VULNERABILITYNAME:Clickjacking

SEVERITY:Info

PLUGIN:HTMLRenderingLayerVulnerability PORT: port 80/443

DESCRIPTION: The web application does not restrict or incorrectly restricts frame objects or UI layersthatbelongtoanotherapplicationordomain,whichcanleadtouserconfusionaboutwhich interface the user is interacting with.

SOLUTION:

- SettheX-Frame-OptionsHTTPresponseheadertodenyorsame-origintocontrolhowyour site can be framed. This is supported by most modern browsers.
- Utilizeframe-bustingJavaScriptcodeinwebapplicationstopreventtheembeddingofyour

sitewithinmaliciousframe's.Thiscodecandisruptclickjackingattempts.

- ImplementaContentSecurityPolicytorestrictwhichdomainscanembedyoursitein iframes. This can help prevent unauthorized framing.
- ImplementadditionalsecuritycontrolstopreventUIredressattacks,suchasclickjacking, within your web application.

BUSINESS IMPACT: To effectively reduce the business consequences resulting from CWE-1021, organizations must prioritize the implementation of protective measures, such as frame-busting code.Simultaneously,educatingusersonsafebrowsingpracticesplaysacrucialroleinpreventing clickjacking incidents. Additionally, routine security assessments and testing are pivotal for identifying and mitigating vulnerabilities associated with clickjacking. These actions are of paramount importance in upholding user trust, ensuring data protection, and safeguarding the organization's reputation.

1. VULNERABILITYNAME:webserverallowspasswordauto-completion SEVERITY: Low

PLUGIN:SSL/TLSDiffie-HellmanModulus<=1024Bits(Logjam) PORT: port 443

DESCRIPTION: Weaknesses in this category are related to the design and implementation of data confidentialityandintegrity.Frequentlythesedealwiththeuseofencodingtechniques,encryption libraries, and hashing algorithms. The weaknesses in this category could lead to a degradation of the quality data if they are not addressed.

SOLUTION:

- Implementsecurepasswordstoragemechanisms,suchasusingstrongandsalted cryptographic hashing algorithms like crypt or script.
- Implementrobustencryptionkeymanagementpractices,includingsecurekeystorage,key rotation, and access controls.
- Utilizewell-establishedandprovencryptographiclibrariesandalgorithmsforencryption and decryption.

- Usesecureencryptionprotocols,likeTLS/SSL,fordatatransmissionovernetworksto protect data in transit

BUSINESS IMPACT: To effectivelylessen the business consequencesassociated with CWE-310, organizationsmustprioritizetheadoptionofsecurecryptographicpractices.Thisentailsensuring proper password storage and robust encryption key management. Simultaneously, conducting routine security assessments and testing is pivotal in detecting and mitigating vulnerabilities relatedtocryptographicissues.Strivingforcompliancewithpertinentdataprotectionregulations and industry standards is equally essential. These actions are of paramount importance in the protectionofsensitivedata,theupholdingofusertrust,andthepreservationoftheorganization's esteemed reputation.

S.NO	VULNERABILITYNAME	SEVERITY	PLUGINS
1.	Cross-sitescripting(DOMbasedXSS)	Medium	MultipleXSS
2.	jQuery1.3<3.5.0MultipleXSS	Medium	CGIAbuse:XSS
3.	Information exposure (web server HTTPheaderinternalIPdisclosure)	Low	Webserver HTTP HeaderInternalIP Disclosure

4.	Informationexposure (SSL(Multiple Issues))	Info	SSLCertificate Information
5.	Informationexposure (HTTP(Multiple Issues))	Info	HTTPInformation
6.	OSidentificationfailed	Info	TCP/IPRemote Probing

TARGET WEBSITE:vit.ac.inTARGETIPADDRESS:122.184.65.22

Report:

1. VULNERABILITYNAME:Cross-sitescripting(DOMbasedXSS) SEVERITY: Medium

PLUGIN:MultipleXSS PORT: port 443

DESCRIPTION: It occurs when a malicious script is injected directly into a vulnerable web application.ReflectedXSSinvolvesthereflectionofamaliciousscriptofawebapplication,onto a user's browser. DOM-XSS: DOM stands for Document Object Model and is a programming interfaceforHTMLandXMLdocuments.Itrepresentsthatprogramscanchangethedocument structure, style and content. A webpage is a document, and this document can be either displayed in the browser window or as the HTML Source.

SOLUTION:

- Wheninteractingwithdatabases,useparameterizedstatementsorpreparedstatements to avoid SQL injection, which can be a vector for XSS.
- Sanitizeandvalidatealluserinputsandensurethatanydatadisplayedonthewebpage is properly encoded. Use output encoding libraries or functions to prevent script injection.
- AvoidusingDOMmanipulationmethodsthatcanintroducevulnerabilities.Becautious with inner HTML, document. Write, and other methods that can execute scripts.

- Considerusingwell-establishedJavaScriptframeworksandlibrariesthatincludebuilt- in security features to prevent DOM XSS.

BUSINESSIMPACT:Theapplicationstoresdangerousdatainadatabase,messageforum,visit or log, or other trusted data store. Later, the dangerous data is subsequently read back into the applicationandincluded in dynamiccontent.Froman attacker's perspective, the optimalplace to inject malicious content is in an area displayed to many users or particularly interesting users. Interesting users typically have elevated privileges in the application or interact with sensitive data that is valuable to the attacker. Ifone of these users executes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain accessto sensitive data belonging to the user.

1. VULNERABILITYNAME:jQuery1.2<3.5.0MultipleXSS

SEVERITY: Medium PLUGIN:CGIAbuse:XSS

PORT:port443

DESCRIPTION: It occurs when a malicious script is injected directly into a vulnerable web application.ReflectedXSSinvolvesthereflectionofamaliciousscriptofawebapplication,onto a user's browser. Stored XSS (Persistent XSS): In this type of attack, the malicious script is permanently stored on a server or in a database, often in user-generated content like comments or forum posts. When other users view the affected content, the script executes in their browsers, potentially compromising their data or sessions. Reflected XSS: Reflected XSS occurs when the malicious script is embedded in a URL and immediately executed when a victim clicks on a manipulated link. The script is not stored on a server but is reflected off a web application, making it a one-time attack. DOM-based XSS: DOM stands for Document Object Modelandis a programming interface forHTML andXML documents. It represents that programscanchangethedocumentstructure, styleandcontent.Awebpageisadocument,and this document can be either displayed in the browser window or as the HTML Source.

SOLUTION:

- Themostimportantrecommendationistoupdatetothelatestversionofj Query.Newer versions typically include security patches, bug fixes, and performance improvements.
- StayvigilantaboutjQueryupdatesandsecurityannouncements.Subscribetorelevant security mailing lists or forums to receive notifications about new releases.

- A Content Security Policy (CSP) can help mitigate various types of client-side vulnerabilities,includingCross-SiteScripting(XSS).ConsiderimplementingaCSPin your web application to restrict the sources from which scripts can be loaded.

- If updating jQuery is not immediately possible, review your code for potential security issues.Ensurethatyouareescapingorsanitizinguserinputsandthatyouareusingsafe coding practices to prevent XSS and other security vulnerabilities.

BUSINESSIMPACT:Theapplicationstoresdangerousdatainadatabase,messageforum,visit or log, or other trusted data store. Later, the dangerous data is subsequently read back into the applicationandincluded in dynamiccontent.Froman attacker's perspective, the optimalplace to inject malicious content is in an area displayed to many users or particularly interesting users. Interesting users typically have elevated privileges in the application or interact with sensitive data that is valuable to the attacker. Ifone of these users executes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain accessto sensitive data belonging to the user.

1. VULNERABILITYNAME:InformationExposure(WebServerHTTPHeaderInternalIP Disclosure)

SEVERITY:Low

PLUGIN:WebServerHTTPHeaderInternalIPDisclosure PORT: port 80

DESCRIPTION:Theproductexposessensitiveinformationtoanactorthatisnotexplicitly authorized to have access to that information.

SOLUTION:

- Carefullyreviewyourwebserver'sconfigurationfiles(e.g.,Apache'shttpd.conf,Nginx's nginx.conf) to identify anywhere internal IP addresses are inadvertently included in HTTP response headers.
- RemoveorreplaceanyinternalIPaddressesintheserverconfigurationfileswith appropriate placeholders or public IP addresses.
- If you use proxy servers or load balancers, ensure that they are configured to hide internalIPaddressesandonlyexposepublicIPaddressesinstancesinHTTPheaders.
- Reviewand configure HTTPresponse headers (e.g.,Server, X-Powered-By) to limit the exposureofserverandtechnologydetails,reducingthepotentialfordisclosingintern al IP addresses.

BUSINESS IMPACT: To effectively reduce the business consequences arisingfrom SSL issues, organizations must give utmost priority to establishing a secure SSL/TLS configuration, conductingfrequent securityassessments and testing. Adheringto dataprotection regulations andindustrystandardsisimperative.Theseactionsplayapivotalroleinsafeguardingsensitive data, upholding user trust, and safeguarding the organization's esteemed reputation.

1. VULNERABILITYNAME:InformationExposure(SSL(MultipleIssues)) SEVERITY: Info

PLUGIN:SSLcertificateInformation PORT: port 443

DESCRIPTION:Theproductexposessensitiveinformationtoanactorthatisnotexplicitly authorized to have access to that information.

SOLUTION:

- Configureyourwebservertousethelatestandstrongestencryptionprotocols,suchas TLS 1.2 or higher. Disable outdated and insecure protocols like SSLv3.
- ImplementPerfectForwardSecrecytoensurethateveniftheprivatekeyis compromised, previously recorded encrypted traffic remains secure.
- Safeguardyourprivatekeysbystoringthemsecurelyandensuringtheyarenot accessible to unauthorized parties.

BUSINESS IMPACT: To effectively reduce the business consequences arisingfrom SSL issues, organizations must give utmost priority to establishing a secure SSL/TLS configuration, conductingfrequent securityassessments and testing. Adheringto dataprotection regulations andindustrystandardsisimperative.Theseactionsplayapivotalroleinsafeguardingsensitive data, upholding user trust, and safeguarding the organization's esteemed reputation.

1. VULNERABILITYNAME:InformationExposure(HTTP(MultipleIssues)) SEVERITY:

   Info

PLUGIN:HTTPinformation PORT: port 80 /443

DESCRIPTION:Theproductexposessensitiveinformationtoanactorthatisnotexplicitly authorized to have access to that information

SOLUTION:

- Minimizetheuseofunnecessaryredirectsastheycanincreasepageloadtimes.Use301 (permanent) redirects for consistent content.
- Regularlycheckforbrokenlinks(404errors)andfixthemtoensureusersfindthe content they are looking for.
- ProperlyconfigureCORStocontrolwhichdomainsareallowedtomakerequeststoyour server.
- MigrateyourwebsitefromHTTPtoHTTPStoensuresecuredatatransmission.Thisis essential for user trust and search engine ranking.

BUSINESSIMPACT: To effectively reduce the business repercussions ofHTTP issues, organizations must place a strong emphasis on ongoing monitoring and enhancement of their webservices.Consistentperformancetestingandsecurityassessments,coupledwithproactive maintenance,areindispensabletoensureaseamlessandsecureonlinepresence.Furthermore, offering timely and helpful customer support and transparent communication when HTTP issues arise is instrumental in mitigating adverse effects on user trust and satisfaction.

1. VULNERABILITYNAME:OSIdentificationFailed SEVERITY: Info

PLUGIN:TCP/IPremoteprobing PORT: N/A

DESCRIPTION:OS identification failed refers tothe inability of a system or software to accuratelyrecognizetheoperatingsystemrunningonadeviceornetwork.Thisissuecanresult from various factors such as misconfigurations, networkissues, orcompatibilityproblems. The failure to identify the OS correctly can lead to security vulnerabilities, hindered software updates, and potential operational disruptions. Resolving this issue promptly is crucial to ensure accurate security measures and the smooth functioning of the system or network.

SOLUTION:

- Minimizetheuseofunnecessaryredirectsastheycanincreasepageloadtimes.Use301 (permanent) redirects for consistent content.
- Regularlycheckforbrokenlinks(404errors)andfixthemtoensureusersfindthe content they are looking for.
- ProperlyconfigureCORStocontrolwhichdomainsareallowedtomakerequeststoyour server.

- MigrateyourwebsitefromHTTPtoHTTPStoensuresecuredatatransmission.Thisis essential for user trust and search engine ranking.

BUSINESSIMPACT:Itmayleadtooperationalinefficiencies,potentialsecurityvulnerabilities, non-compliancewithindustryregulations,andapossiblelossofcustomertrust.Suchfailures couldresultindowntime,compromiseddatasecurity,regulatorypenalties,anddamagetothe company's reputation, potentially leading to financial losses and decreased market competitiveness. Resolving this issue promptly is crucial to mitigate these risks and maintain the smooth functioning of the organization.

Stage–3

Title:

Designandapplycontext-awareaccesscontrolsbasedonuseridentity,deviceposture,location,and application risk.

Context-aware access controls represent the operational pinnacle of a Zero Trust architecture, moving beyond static rules to create a dynamic and adaptive security perimeter around every application. In a modernenterprise,whereusersaremobile,devicesarediverse,andthreatsaresophisticated, granting access based solely on a username and password is a dangerous oversimplification. Designing and applying context-aware controls means building a policy engine that consumes multiple, real-time signals about an access request and renders an intelligent decision: to allow, to block, to limit, or to challenge.Thisapproachensuresthatthesecuritypostureisnotaflat,always-ongatebutaresponsive system that tightens or loosens based on the risk of the specific moment.

The design of such a system begins with a deep integration between the access broker, such as Zscaler Private Access (ZPA), and the organization's existing security and identity infrastructure. The first and mostfundamentallayeris useridentity.Thisisnotsimplyausername,butarichsetofattributespulled from the corporate Identity Provider (IdP) like Azure AD or Okta. Integration via SAML ensures that when a user authenticates through the ZPA client, they are verified with multi-factor authentication (MFA)bytheIdP.ZPAtheningestsnotjusttheuser'sname,buttheirgroupmemberships(e.g.," Finance –PayrollManagers,""Engineering–SourceCodeContributors"),roles,anddepartment.Thisallowsfor thecreationofgranularpoliciesthatareintrinsicallytiedtotheuser'sfunctionwithintheorgan

ization. For instance, a policy can be written in plain language: "Allow members of the 'Finance-Payroll' group to access the 'ADP Payroll' application."

However, a valid identity on a compromised device is still a critical threat. This is where the second layer,device posture, becomes essential. The design incorporates continuous checks on the security health of the endpoint attempting the connection. Through integrations with Endpoint Detection and Response (EDR) tools like CrowdStrike or SentinelOne, and Mobile Device Management (MDM) solutions like JAMF or Intune, ZPA can assess a device's real-time hygiene. The policy engine evaluates factorssuchas:Isthedevice'sdiskencryption(BitLocker/FileVault)enabled?Istheantivirussoftware active and its definition database up-to-date? Has the operating system been patched to the latest security baseline? Is the device rooted or jailbroken? Is there a high-risk score being reported by the EDR tool due to suspicious activity? If a device fails these checks—for example, a user's laptop has its firewall disabled—the context-aware policy can automatically trigger an action. It might block access entirely,oritmightgrant"remediationaccess,"routingtheusertoacaptiveportaltodownload updates orcontactIT,whilepreventingthemfromreachinganybusiness-criticalapplications.Thisensuresthat a vulnerable endpoint cannot become a beachhead for an attacker to move laterally into the corporate environment.

The third contextual layer is location and network environment. The physical or virtual location from which a user connects provides a powerful signal for risk assessment. A finance director accessing the payroll system from their home office in the same city is a low-risk event. The same user attempting to connect from a country with a high prevalence of cybercrime, or from an anonymizing VPN service, should be treated withextreme suspicion. Context-aware policies can be designed to enforce this logic. For example, access to a source code repository containing intellectual property could be restricted to users connecting from a corporate office or a pre-approved home IP address range. If a legitimate user is traveling, the policy might allow access but require a step-up authentication, such as a hardware token, or grant only read-only permissions. This layer can also consider the security of the network itself; a connection from a public, unencrypted Wi-Fi hotspot might trigger stricter controls than one from a known, secure corporate network.

The final and often most strategic layer is application risk. Not all applications are created equal, and their access policies should reflect their value and sensitivity. In the design phase, applications are categorized and tagged based on their risk profile. An internal wiki used for cafeteria menus would be classified as low-risk, whereas a customer database, a financial trading platform, or a source code repository would be classified as high or critical risk. This tagging allows policies to be layered and dynamic. A single user might have access to multiple applications, but the controls applied to each session will differ based on the application's risk. For the low-risk wiki, a valid user identity and a compliant device might be sufficient. However, for the high-risk financial platform, the policy engine mightrequireallfourlayerstoalign:theusermustbeinaspecificgroup,onafullypatchedandmanaged device,connectingfromatrustedlocation,andmayevenbesubjecttosessionrecordingor

time-of-day restrictions. This ensures that security resources and scrutiny are applied proportionally to the actual risk, preventing "blanket" access and ensuring that the most valuable assets have the most robust defenses.

In practice, applying these controls within ZPA means using the policy builder to create conditional statements. A policy might read: "Allow access to 'Application A' if User is in 'Group X' AND Device Posture is 'Compliant' AND Location is 'Not Restricted' AND Application Risk is 'Low'." Alternatively, a more complex policy for a critical application might be: "Allow access to 'Application B' if User is in 'Group Y' AND Device Posture is 'Highly Secure' AND Location is 'Corporate Network' AND Time is 'Business Hours', otherwise, if Location is 'Remote', require Step-Up Authentication." By combining these signals, the organization creates a security posture that is finely tuned, highly resilient, and fundamentally adaptive to the context of every single access attempt, thereby upholding the core Zero Trust principle of "never trust, always verify."

Conclusion:

Stage 1: In conclusion, web application testingis a crucial process that ensures the security, functionality,andreliabilityofweb-basedsoftware.Itinvolvesacomprehensiveevaluationofvarious aspects,includinguserinterface,functionality,performance,andsecuritytoidentifyandrectifyissues before theyimpact end-users. This process notonlyenhances the qualityofweb applications butalso bolsters their resilience against potential threats and vulnerabilities. In an age where online services andapplicationsareintegraltoourdailylives,effectivewebapplicationtestingisessentialtodelivera seamless and secure user experience.

Stage2:TheNessusreportforthespecificwebsitehashighlightedkeysecurityinsights.Itidentified vulnerabilities, categorized by severity, with a focus on critical and high-risk issues that need immediate attention. Recommendations for addressing these vulnerabilities include patching, reconfiguration, and other security measures, with a priority on actions that can have the most significant impact. Compliance with industry standards and best practices is considered, ensuring alignmentwithrecognizedsecuritybenchmarkslikeOWASPguidelines.Thereportundersco resthe need for continuous monitoring, regular updates, and ongoing security efforts to maintain a strong security posture. In summary, the Nessus report offers a clear view of the website's security state, provides guidance on mitigating vulnerabilities, and stresses the importance of sustained vigilance against evolving threats.

Stage3:

The implementation of Zscaler Private Access marks a pivotal shift from a vulnerable, network- centric security model to a resilient, identity-centric Zero Trust architecture. By enforcing least- privilegeaccessandrenderingprivateapplicationsinvisible

totheinternet,thisprojecteffectively neutralizes the threats of lateral movement and network-based attacks. The solution not only fortifies the organization's security posture against modern cyber threats but also delivers a seamless and high-performance experience for a distributed workforce. Furthermore, the decoupling of access from the network simplifies IT operations, reduces dependency on legacy VPN infrastructure, and provides granular visibility into user-application interactions. Ultimately, this initiative establishes a future-ready foundation for secure digital transformation..

FutureScope:

Stage1:futurescopeofwebapplicationtesting

Thefuturescopeofwebapplicationtestingispromisingandevolvingrapidly,drivenbythe continuous growth of the internet and web-based applications.

Herearesomekeyaspectsofitsfuturescope:

- Increased Demand: As more businesses and services move online, the demand for web applicationscontinuestogrow.This,inturn,increasesthedemandforwebapplicationtesting to ensure security, reliability, and functionality.
- Advanced Technologies: The complexity of web applications is rising with the integration of advancedtechnologieslikeAI,IoT,andblockchain.Testingthesecutting-edgeapplicationswill require specialized skills and tools.
- SecurityEmphasis:Withthegrowingnumberofcyberthreatsanddatabreaches,security testing for web applications will become even more critical. Testers will need to focus on vulnerabilities, data protection, and compliance with regulations like GDPR.
- Mobile and Cross-Browser Testing: Mobile usage is on the rise, and web applications must be responsiveandfunctionalonvariousdevicesandbrowsers.Testingforcross-compatibilitywill be essential.
- Performance Testing:As userexpectations forspeedandperformance increase, load testing, stresstesting,andotherperformancetestingtypeswillbecrucialtoensurewebapplications can handle traffic spikes.

Stage2:futurescopeofthetestingprocessyouunderstood.

The future scope of the web application testingprocess, particularly in terms of identifying vulnerabilities, is exceedingly promising due to the continuous growth of digital platforms, the escalatingimportanceofcybersecurity,andtheever-evolvingthreatlandscape.Herearesomekey

aspectsthathighlighttheprospectivescopeofwebapplicationtestingforvulnerabilitydiscovery:

- AI-DrivenTesting:Theintegrationofartificialintelligence(AI)andmachinelearning(ML)into web application testing tools will revolutionize the way vulnerabilities are identified. AI algorithms can swiftly scan vast amounts of code and data to pinpoint vulnerabilities that might elude human testers.
- IoTandMobileAppTesting:WiththeproliferationofInternetofThings(IoT)devicesandthe increasing usage of mobile applications, the scope of web application testing will extend to encompass these areas. Ensuring the security of IoT devices and the interfaces they use will become critical.

- Blockchain and Cryptocurrency Security: As blockchain technology and cryptocurrencies continue to gain traction, security testing will be imperative to safeguard transactions and digitalassets.Ensuringtherobustnessofblockchain-basedapplicationswillbeaspecialized

niche in web application testing. Serverless Architectures: With the adoption of serverless computing, web application testing will need to adapt to assess the security of serverless functionsandAPIs.Ensuringthatserverlesscomponentsarefreefromvulnerabilitieswillbe paramount.

- Container Security: As containerization technologies like Docker and Kubernetes become ubiquitous, web application testing will extend to cover container security. This includes ensuringthatcontainerimagesandorchestrationconfigurationsarefreefromvulnerabilities.

Stage3:futurescopeof AwareAccessControl

ThesuccessfuldeploymentofZPAlaysthegroundworkforabroader,moreintegratedsecurity ecosystem.Futureenhancementscanbeexploredtofurthermaturetheorganization'ssecurity capabilities:

- Integration with Zscaler Internet Access (ZIA): ConvergingPrivate Access (ZPA) with Internet Access(ZIA)tocreateaunifiedSecureAccessServiceEdge(SASE)platform,managingall web and private traffic through a single policy framework.
- AdvancedDevicePosture Checking:Movingbeyondbasiccompliancetoincorporatereal-time risk scores from EDR tools, blocking access if a device shows signs of active compromise.
- PrivilegedRemoteAccess: ExtendingZPAtothird-partyvendorsandcontractorswithtime- bound, audited access to specific critical systems, replacing jump boxes and bastion hosts.

- IoT/OT Segmentation: Applying the same micro-tunneling principles to Internet of Things (IoT)andOperationalTechnology(OT)devicestoensuretheycanonlycommunicatewith specific management servers.
- AI-DrivenAnomalyDetection: LeveragingmachinelearningonZPAlogstodetectbehavioral anomalies, such as a user accessing an application at an unusual hour or from a strange location, triggering automated MFA challenges or access revocation.
- Cloud Workload Protection: Utilizing ZPA to secure connections between containers and microservicesinmulti-cloudenvironments(AWS,Azure,GCP),ensuringeast-westtraffic between workloads is encrypted and authenticated.
- Automated Provisioning/Deprovisioning: Enhancing the identity provider integration to automaticallyrevokeapplicationaccessthemomentanemployeeisterminatedorchanges roles, ensuring near real-time access control.
- DigitalExperienceMonitoring(DEM): ImplementingDEMtoolstoproactivelymonitortheend- user experience, identifying network latency or application performance issues before they impact productivity.

TopicsExplored:

1. Zscaler
2. Zerotrust
3. ZPA
4. VPN
5. MISP
6. CollegeNetworkInformation
7. DeploymentofSOCintheCollege
8. ThreatIntelligence
9. IncidentResponse

ToolsExplored:

- NessusScanner